Sommario

Capitolo 1 - Introduzione alla sicurezza delle reti e dei sistemi informativi 4

1.Parlare degli attacchi sniffing, spoofing e hijacking e descrivere le opportune misure di sicurezza. 4

2.Spiegare che cos'è il social engineering, fare un esempio di questo attacco, indicare le contromisure che un'azienda può adottare per difendersi. 4

3.Descrivere un attacco phishing e quali sono le misure per limitarlo. 4

4.Spiegare che cosa è un attacco connection hijacking, come può essere condotto e quali contromisure si possono adottare. 4

5.Spiegare cosa si intende con malware food chain, chiarire perché ha questo nome ed illustrare con un esempio. 5

6.Spiegare cosa sono gli attacchi di phishing e whaling 5

7.Che cosa significano le seguenti parole: Vulnerabilità, minaccia e security control. Come sono correlate? 5

8.Che cosa significano le seguenti parole? Vulnerabilità, minaccia, asset ed attacco? Come sono correlate? 5

9.Spiegare cosa vuol dire DoS e fare esempi; perché è difficile da scoprire un attacco DoS; come difendersi da questi attacchi. 5

10.Cos'è Stuxnet? Come funziona e che lezioni possiamo concluderne? 6

11.Dire cos'è la Windows of Exposure e dove si può agire per ridurla. 6

12.Bruce Scheiner ha scritto "security is a process, not a product" spiegare il significato di questa affermazione e fornire un esempio pratico di sua implementazione con elementi tecnici. 7

13.Definire i termini minaccia, vulnerabilità e security control, quindi spiegare quali relazioni intercorrono tra di loro e fornire un esempio per ciascun termine nel caso di una terna correlata 7

14.Spiegare brevemente la proprietà di sicurezza denominata integrità dicendo da quali attacchi protegge sia quando i dati a cui si riferisce sono memorizzati sia quando sono trasmessi. 7

Capitolo 2 - Concetti base di sicurezza informatica 8

15.Descrivere HMAC indicando i pregi e i difetti. 8

16.Descrivere le proprietà di autenticazione e integrità di HMAC rispetto la firma elettronica. 8

17.What is integrity? Mention some possible attacks related to it? 8

18.Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1kB con digest SHA-1 e chiave RSA 1024 bit. 9

19.Cosa significano i seguenti acronimi: DSA, RC-4, RIPEMD? 9

20.Dare una breve descrizione di: RC4, RSA, RIPEMD. 9

21.Differenza algoritmi stream e a blocchi 9

22.Perché gli algoritmi di stream sono più veloci? 10

23.Un'azienda deve scambiare con un'altra dei file ma possono utilizzare soltanto una chiave di 12 caratteri max; indicare come deve essere implementato il sistema (NOTA: volevano nella soluzione che si parlasse anche di kdf) 10

24.Un messaggio di 28 byte viene cifrato con DES-CBC: quanti byte verranno inviati in totale? 10

25.Se devo cifrare in modalità DES-CBC un file da 84 byte, quanti byte trasmetterò in rete? 10

26.Avendo un file da 1500 byte, se lo cifro con 3DES-CBC quanto sarà grande il file finale? 10

27.CBC vs CTR: come funzionano, vantaggi e svantaggi 11

28.Due utenti desiderano scambiarsi via rete una serie di documenti informato ASCII (.TXT). Suggerire quali operazioni è opportuno svolgere su questi documenti prima di trasmetterli per resistere ad attacchi sulla rete (insicura). Si tenga presente che i documenti non contengono info riservate. Nota: non si usino protocolli o formati dati complessi. Si esprima la soluzione tramite formula (usando termini appropriati, come aes(k,d) piuttosto che enc(k,d)) 11

29.Utente A vuole mandare un messaggio segreto e autenticato agli utenti B e C, tutti e tre hanno un paio di chiavi RSA a testa. Descrivere il formato del data block per inviare il messaggio con le richieste proprietà di sicurezza. 11

30.Parlare del meccanismo del keyed digest (cos'è, quando e come si usa, vantaggi e svantaggi). 11

31.Parlare del keyed-digest e la firma digitale, quali sono le proprietà che offrono, vantaggi e svantaggi? 12

32.Un'azienda vuole fare firma digitale su tutti i suoi documenti e conservare sia i documenti sia le firme in modo da poterli verificare anche in futuro. Che cosa usare? Che cosa deve memorizzare insieme alla firma? 12

33.Quali proprietà di sicurezza offre la firma digitale, come si realizza, quali parti della firma offrono quelle proprietà di sicurezza. 12

34.Perché l'algoritmo SHA-1 è deprecato? Suggerire una possibile e valida alternativa e motivare perché questa sia migliore di SHA-1. 13

35.Ordinare dal più veloce al più lento i seguenti algoritmi: SHA, AES_ECB, AES_CBC, RC4 13

36.Dati i seguenti algoritmi di cifratura, ordinarli dal più lento al più veloce: AES, DES, RC4, 3DES. 13

37.Descrivi la crittografia a curve ellittiche. 13

38.Dire i due principali vantaggi degli algoritmi basati su ECC 14

39.Descrivi l'algoritmo di keyed-digest CBC-MAC. 14

40.Uno dei primi metodi per criptare i dati? 14

41.Su sistemi embedded spesso si preferisce ECDSA rispetto a RSA: perché? 14

42.Qual è il principale vantaggio della modalità di cifratura CTR? 14

43.Indicare quale attacco all'integrità è possibile se dei dati D vengono protetti con un MAC calcolato nel seguente modo (k è la chiave e h è la funzione di hash): MAC =h (k || D). 14

44.Vantaggi e svantaggi di cifratura fatta con enc(enc(p, k1), k2) con k1 e k2 chiavi diverse ma di lunghezza uguale 15

45.Descrivere la tecnica crittografica ECB identificandone vantaggi e svantaggi. 15

46.Quale delle seguenti tecniche – firma digitale, cifratura simmetrica, keyed-digest –sarebbe da preferire per proteggere l'integrità di un flusso di pacchetti a 1 Gbps? Giustificare la scelta. 15

47.Quale tecnica è meglio usare per proteggere dati trasmessi in rete da attacchi di tipo replay? Cifratura simmetrica, cifratura asimmetrica, keyed-digest, altro? Giustificare. 15

48.Due utenti devono scambiarsi dei file di testo formato ASCII (txt) non riservati. Come fanno a garantire che non vengano modificati durante il transito? Spiegare quali funzioni di sicurezza usare e enunciare la formula che produce il documento X trasmesso rispetto al documento originale. Si usino nomi significativi (es. aes(K,D) rispetto a enc(K,D). 15

49.Si deve trasmettere cifrata una password da 12 caratteri con 2 byte di sale con AES. Cosa si usa tra ECB, CBC e CBF? 16

50.Dovendo cifrare con AES una password da 12 caratteri con 2 byte di sale è meglio usare ECB, CBC o CTR? 16

51.Firma digitale con digest SHA256, chiave privata RSA-2048 su un file da 10MB. Qual'è la dimensione della firma? 16

52.Come possono inviarsi un file due tizi che condividono una password..... 16

53.Si deve firmare un documento da 10 MB con digest SHA-1 e chiave RSA. Quanto è grande esattamente la firma del documento?..... 16

54.Quali algoritmi si possono usare per scambiare chiavi segrete? 16

55.Hash per calcolare la password partendo da un seme...... 16

56.Per quale applicazione è stato inventato il CTS? 16

57.Spiegare cos'è la modalità operativa CTS qual è l'idea principale su cui si basa la sua implementazione e perchè sta assumendo sempre più rilevanza 16

58.Perché non si usa 2DES e si preferisce 3DES? 17

59.Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1 kB con digest SHA-1 e chiave RSA 1024 bit...... 17

60.Quali algoritmi base (non strutture dati complesse) si possono utilizzare per garantire riservatezza di un file situato su un server di cui non ci si fida? 17

61.Spiegare il termine security through obscurity. Spiegare perché alcuni dicono sia buono ed altri no. 17

62.Spiegare la authenticated encryption...... 17

63.CBC e CTR mode: spiegare, vantaggi e svantaggi...... 18

64.Qualcuno ti ha inviato un file firmato digitalmente con RSA e SHA-. . . , insieme al certificato del firmatario e al certificato della sua CA. Descrivere come validare la firma, identificare le informazioni richieste ed ottenere l'accesso ad esse. 18

65.Descrivere DH, i suoi problemi e le soluzioni ad essi. 18

66.RSA, RC4, SHA-1, . . . : qual è l'intruso e perché?..... 18

67.Spiegare brevemente la tipologia di cifratura simmetrica e quella asimmetrica, indicando i vantaggi e svantaggi di ciascuna tipologia...... 18

Capitolo 1 - Introduzione alla sicurezza delle reti e dei sistemi informativi

1. Parlare degli attacchi sniffing, spoofing e hijacking e descrivere le opportune misure di sicurezza.

Per **sniffing** si intende la lettura di pacchetti in transito su una rete destinati a un nodo diverso dal mio, con lo scopo di catturare informazioni sensibili. Per contrastarlo è necessario inserire un meccanismo di cifratura del Payload dei pacchetti. Lo sniffing è facile da attuare in **reti broadcast**, quindi un'altra misura di sicurezza da applicare è proteggere usando reti non broadcast.

Per **IP spoofing** si intende la falsifica del proprio indirizzo IP con l'indirizzo IP della vittima, al fine di accedere a sistemi a cui non sono utilizzato. Per contrastarlo è necessario evitare tecniche di autenticazione basate su indirizzo di rete.

L'Hijacking, o **man in the middle**, consiste nel prendere il controllo di un canale di comunicazione client – server al fine di modificare, replicare o cancellare pacchetti. Per contrastarlo è necessario inserire una verifica di integrità nei pacchetti inviati, implementare un meccanismo di autenticazione e riservatezza.

2. Spiegare che cos'è il social engineering, fare un esempio di questo attacco, indicare le contromisure che un'azienda può adottare per difendersi.

Per social engineering si intende un tipo di attacco che va a sfruttare non le vulnerabilità informatiche ma le vulnerabilità umane, agendo su pressioni psicologiche. Questo tipo di attacco si basa sulla dimostrazione della conoscenza dell'azienda o della persona. Un esempio di questo tipo di attacco è il mail **phishing**, ossia l'invio di email false con lo scopo di far cliccare l'utente su link che riportano a siti malevoli. Un'azienda, per difendersi da questo tipo di attacco, può istruire i suoi dipendenti sull'esistenza di queste email e sui rischi che comportano.

3. Descrivere un attacco phishing e quali sono le misure per limitarlo.

L'attacco di tipo phishing consiste nell'attrarre la vittima su un server fasullo per catturarne le credenziali o convincerlo a installare un plugin, che spesso si tratta di un virus. Le varianti del phishing sono **Spear Phishing** che include nella mail fasulla molti dati personali al fine di renderla più credibile e attrarre di più la vittima, e **Whaling** che invece mira ad attaccare figure importanti nell'azienda, come i CEO. Una misura che un'azienda può adottare per mitigare questo tipo di attacchi è istruire i propri impiegati circa questi rischi.

4. Spiegare che cosa è un attacco connection hijacking, come può essere condotto e quali contromisure si possono adottare.

Per Hijacking, o Man in the middle, si intende prendere il controllo di una connessione di rete tra client e server al fine di manipolare o inserire ulteriori pacchetti. L'attaccante riceve pacchetti da un lato, li manipola e reindirizza i pacchetti manipolati verso la destinazione originaria. Per contrastarlo si possono inserire misure che verifichino **l'integrità dei pacchetti**, autenticazione e riservatezza.

5. Spiegare cosa si intende con malware food chain, chiarire perché ha questo nome ed illustrare con un esempio.

La Malware food chain è un processo utilizzato dai criminali informatici a scopo di lucro. Consiste in una serie di servizi offerti in modo tale da semplificare gli attacchi informatici, dando la possibilità ai cybercriminali di avere facilmente a disposizione elementi per scoprire vulnerabilità, sviluppare un malware e infine distribuirlo. Si compone di 4 fasi:

- Scoperta di una vulnerabilità, messa in vendita sul dark web
- Vendita della vulnerabilità nel dark web ai creatori di malware e toolkit
- Vendita dei malware toolkit per sfruttare le vulnerabilità
- Vendita di una rete di distribuzione del malware

È una vera e propria organizzazione criminale per trarre profitto negli attacchi verso una data azienda o multinazionale. Scrivere il malware è un pezzo della catena. Perché questo sistema stia in piedi è necessario avere un'organizzazione criminale basata su minacce e ricatti al fine di evitare che chi lavori al malware sfrutti le vulnerabilità per un proprio tornaconto personale anziché per l'intera organizzazione criminale.

Un esempio di attacco di questo sito può essere la vendita nel dark web di credenziali rubate in un servizio, oppure **Zeus**, che installava dei keylogger o fungeva da trojan.

6. Spiegare cosa sono gli attacchi di phishing e whaling

Gli attacchi di **phishing** sono quegli attacchi che fanno parte della categoria di attacchi social engineering, e consistono nell'invio di mail che adescano l'utente a cliccare su link che riportano a siti malevoli, al fine di catturarne le credenziali o far installare plugin malevoli. Il **whaling** è un caso particolare del phishing, in cui l'obiettivo è attaccare i pezzi grossi di aziende o istituzioni.

7. Che cosa significano le seguenti parole: Vulnerabilità, minaccia e security control. Come sono correlate?

La **vulnerabilità** è considerata come la parte debole di un asset (una password debole o un bug).

Una **minaccia** invece è lo sfruttamento intenzionale (attacco) o accidentale (evento negativo) di una vulnerabilità

Security Control servono nel campo della sicurezza per proteggere le vulnerabilità presenti negli asset, e fanno parte delle possibili mitigazioni da attuare.

8. Che cosa significano le seguenti parole? Vulnerabilità, minaccia, asset ed attacco? Come sono correlate?

Per **asset** si intende l'insieme dei beni, dati e persone necessari all'erogazione di un servizio informatico.

Un **attacco** è una minaccia catalogata come sfruttamento intenzionale di una vulnerabilità presente in un asset.

9. Spiegare cosa vuol dire DoS e fare esempi; perché è difficile da scoprire un attacco DoS; come difendersi da questi attacchi.

Gli attacchi di tipo **Denial Of Service** causano un'interruzione della fruizione di un servizio a causa dell'elevato traffico che viene generato verso un dato server. Può essere ad esempio l'invio di allegati molto pesanti in una casella di posta al fine di saturarla e non permettere più di ricevere email, oppure riempire le **tabelle dei server** che registrano le connessioni mediante un SYN attack.

Scoprire questo tipo di attacco è difficile in quanto non è sempre immediato capire se le richieste provengano effettivamente da un attaccante o se semplicemente sono state fatte numerose richieste da parte di client legittimi. Inoltre l'inacessibilità al servizio rende difficile effettuarne una diagnostica.

Non esistono metodi semplici per proteggersi, possono esistere solo palliativi: ad esempio, nel caso delle mail, si possono aumentare le dimenisoni dlela memoria della propria casella o si può aumentare il numero di server nel caso di un attacco di tipo SYN.

10. Cos'è Stuxnet? Come funziona e che lezioni possiamo concluderne?

Stuxnet è un malware del 2010 prototipato dal governo statunitense contro le centrali nucleari iraniane.

La centrale nucleare aveva un sistema informatico per controllare gli impianti industriali cosiddetto **air gap**, ovvero, non era possibile accedere alla rete fisica dall'esterno in quanto disconnessa da internet e senza wifi, pensata unicamente per controllo industriale. Di questo sistema erano note 3 vulnerabilità, una delle quali aveva una patch disponibile, ma non sono state prese in considerazione in quanto si riteneva che essendo una rete isolata fosse immune a qualsiasi attacco proveniente dall'esterno.

L'attacco Stuxnet perciò avviene attraverso l'utilizzo di un **dispositivo USB** inserito nel sistema da un tecnico di manutenzione. Il malware si è riuscito a propagare tramite dischi di rete condivisi, che non avevano alcun tipo di protezione. i dischi condivisi comprendono servizi che erano attivi pur se non necessari nel contesto, e hanno contribuito a espandere il virus.

In seguito alla propagazione Stuxnet è riuscita a sfruttare una vulnerabilità **dei sistemi di controllo di Microsoft**, perciò è riuscita ad avere i privilegi di Microsoft, riuscendo a installare nei dispositivi dei software senza particolari controlli. A questo punto il sistema era a completa disposizione degli attaccanti, in quanto nessun database è stato cifrato quindi i dati venivano catturati in chiaro.

Lezioni da imparare:

- Disabilitare servizi non necessari
- Implementare politiche di sicurezza sempre, anche se si è in un caso di air gap.
- Creare una whitelist di software da installare in modo tale che neanche microsoft possa installare componenti che non ci servono.

11. Dire cos'è la Windows of Exposure e dove si può agire per ridurla.

La finestra di esposizione è il periodo di tempo in cui il sistema è esposto a una minaccia di sicurezza. Si divide in 3 fasi:

1. fase di scoperta:

- un attaccante scopre una nuova vulnerabilità;
- l'attaccante sviluppa un programma di attacco, chiamato *exploit*, che sfrutta tale vulnerabilità;
- L'attaccante inizia ad effettuare degli attacchi, facendo sì che la vulnerabilità diventi pubblica;

2. fase di pubblicazione: le persone cercano di limitare i danni:

- la vittima dell'attacco informa il produttore della vulnerabilità;
- il produttore informa tutti i suoi clienti dell'esistenza di tale problema;
- i clienti aggiornano gli strumenti di difesa (ad es. firme IDS, strumenti di monitoraggio), in attesa di una patch;
- il produttore rilascia una patch;

3. fase di protezione: i clienti applicano la contromisura:

- la patch è resa disponibile a tutti i clienti;
- solo quando tutti installano la patch, il problema può essere considerato risolto.

Per ridurre i tempi di una WOE si possono fare controlli di sicurezza periodici per rilevare le vulnerabilità preventivamente, e notificare il pubblico il prima possibile in caso di attacco così da minimizzare i danni.

12. Bruce Scheiner ha scritto "security is a process, not a product" spiegare il significato di questa affermazione e fornire un esempio pratico di sua implementazione con elementi tecnici.

Questa frase significa che la sicurezza deve essere implementata in tutte le fasi di produzione: non è un semplice prodotto esterno che si compra per poterlo aggiungere a un prodotto già sviluppato. Questa soluzione non è infatti sufficiente per rendere un sistema protetto, dato che il singolo prodotto non è esente da bug. È necessario progettare il sistema di sicurezza usando più sistemi in parallelo, possibilmente di produttori diversi in modo tale da garantire una difesa maggiore.

Un esempio pratico può essere l'aggiunta di un firewall di un produttore e un IDS di un secondo produttore.

13. Definire i termini minaccia, vulnerabilità e security control, quindi spiegare quali relazioni intercorrono tra di loro e fornire un esempio per ciascun termine nel caso di una terna correlata

Vulnerabilità: la parte debole di un asset informatico. Può essere, ad esempio, una password debole o un bug.

Minaccia: un attaccante che sfrutta una vulnerabilità. È un evento intenzionale (attacco) o accidentale che implica una perdita di una proprietà di sicurezza. Ad esempio, può essere un data breach.

Security control: mitigazioni che proteggono contro minacce e proteggono da vulnerabilità. Possono essere VPN, Firewall, IDS.

14. Spiegare brevemente la proprietà di sicurezza denominata integrità dicendo da quali attacchi protegge sia quando i dati a cui si riferisce sono memorizzati sia quando sono trasmessi.

L'integrità è una delle tre funzionalità di sicurezza CIA, che implica il fatto che un dato trasmesso in rete deve arrivare a destinazione così come era stato mandato dalla sorgente. Se ad esempio un MITM si immette in una comunicazione manipolando e cancellando il dato, questa proprietà di sicurezza viene a mancare. La proprietà di integrità protegge infatti da attacchi di cancellazione, filtraggio o manipolazione del dato.

Capitolo 2 - Concetti base di sicurezza informatica

15. Descrivere HMAC indicando i pregi e i difetti.

HMAC (Hashed Based Message Autentication Code) è un algoritmo di keyed-digest, che fa sì che si soddisfano insieme le proprietà di Integrità e Autenticazione. Consiste nel fare un digest del messaggio da mandare, e cifrarlo con una chiave simmetrica K che sia mittente sia destinatario conoscono. Per realizzare un algoritmo HMAC i passi da effettuare sono:

- Definisco un blocco di **B** byte in cui suddividere il messaggio preso in input
- Definisco **L<B** byte di output.
- Calcolo **K'** a partire da K (la chiave simmetrica che entrambe le parti conoscono)
  - Se K<B, aggiungo a K tanti 0 per farla arrivare a una dimensione B
  - Se K>B applico una funzione di hash per ridurre la sua dimensione a B byte.
- Eseguo uno **XOR** tra K' e una stringa fissa chiamata **ipad** e la concateno ai dati di cui voglio fare il digest: calcolo l'hash di questa concatenazione e ottengo un primo output di dimensione L, che chiamerò O1
  - **H(K' XOR ipad || data) = O1**
- Eseguo uno **XOR** tra K' e un'altra stringa fissa, **opad**, e la concateno a O1. Ne calcolo l'hash, e ottengo l'HMAC, sempre di dimensione L.
  - **H(K' XOR opad || O1) = HMAC**

Pregi e difetti:

- Vantaggio nella poca quantità di dati trasmessi
- Prestazioni veloci
- Un unico algoritmo che offre insieme integrità e autenticazione
- Non è vulnerabile agli attacchi di estensione e prefisso tipici del Keyed-digest.
- Difetto: Il difetto tipico degli algoritmi di digest, ovvero, l'integrità non è garantita al 100% in quanto negli algoritmi di digest si possono verificare delle collisioni.

16. Descrivere le proprietà di autenticazione e integrità di HMAC rispetto la firma elettronica.

HMAC è un algoritmo di keyed digest e garantisce insieme Integrità e autenticazione dei dati, dal momento che riassume un messaggio con delle funzioni di hash utilizzando una chiave simmetrica che conoscono sia mittente sia ricevente. Questo algoritmo, tuttavia, non garantisce il principio del non ripudio: il mittente in sede legale potrebbe eventualmente affermare di non aver fatto una data operazione, e non ci sarebbero prove per affermare il contrario. Infatti si fa autenticazione dei dati, non autenticazione del mittente, di conseguenza chiunque potrebbe aver mandato quell'hash.

Per questo motivo l'autenticazione tramite segreto condiviso è utilizzata soltanto quando si hanno grossi problemi di banda (essendo una procedura molto veloce), ma spesso si tende a utilizzare una firma digitale tramite crittografia asimmetrica da applicare al digest. In questo modo, pur essendo una operazione molto lenta, la si applica comunque su poche quantità di dati. La firma digitale garantisce autenticazione del mittente, perché l'hash viene cifrato usando chiave privata. Se il ricevente riesce a decifrare il messaggio con la chiave pubblica relativa, il principio di autenticazione della controparte è soddisfatto. Il certificato X.509 certifica l'identità del mittente.

17. What is integrity? Mention some possible attacks related to it?

L'integrità è un principio della sicurezza informatica che garantisce che un messaggio spedito arrivi a destinazione senza aver subito modifiche, filtraggi o cancellazioni. I possibili attacchi relative al principio di integrità di messaggio o pacchetto sono gli attacchi MITM: un attaccante si immette in una comunicazione tra due entità e applica manipolazione dei dati o dei pacchetti.

18. Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1kB con digest SHA-1 e chiave RSA 1024 bit.

Digest sha-1: blocco da 512 bit, digest da 160 bit.

RSA: algoritmo di crittografia asimmetrica

Suppongo una cifratura simmetrica usando AES-128 CTS (cyphertext stealing), quindi senza il padding. In questo caso le operazioni da fare sono:

- Decifratura della chiave simmetrica K usando la Kpri del mittente, quindi ricevo 1024 (128 byte) bit di dati per decifrare una chiave simmetrica da 128 bit.
- 1024 bit (128 Byte) di chiave pubblica del mittente (in caso non abbia un Hardware Security Mode)
- 1 KB (1024 bytes) di spazio per memorizzare il plaintext
- 160 bit (20 Byte) di spazio per il digest SHA-1

1024 + 20 + 128 + 128 = 1300 byte di dati.

Con un Hardware Security Mode, ne memorizzo soltanto 1172 perché mantiene la chiave pubblica nella propria memoria.

19. Cosa significano i seguenti acronimi: DSA, RC-4, RIPEMD?

DSA è un algoritmo di crittografia asimmetrica che si basa su elevamento a potenza e logaritmi. Si utilizza per fare firma digitale, in quanto la funzione che utilizza se applicata su plaintext causerebbe perdita di dati.

RC4 è un algoritmo di cifratura simmetrica di tipo stream, ovvero, a partire da un seed si genera una chiave da cui viene generato successivamente un keystream di lunghezza pari alla lunghezza del messaggio, e viene applicato uno XOR bit a bit tra keysteam e dati.

RIPEMD è un algoritmo di hash crittografico con blocchi da 512 bit e output da 160 bit. È ritenuto abbastanza buono, ma non è stato mai utilizzato.

20. Dare una breve descrizione di: RC4, RSA, RIPEMD.

RSA è un algoritmo a crittografia asimmetrica a blocchi, e genera le sue chiavi usando due esponenti (Kpub = (E, N), kpri = (D, N) con N = P*Q, numeri primi, E e D sono regolate dalla proprietà matematica secondo cui E* D = 1 + KPHI(N), dove PHI(N) = (Q-1) * (P-1)). Importante è che il prodotto dei due esponenti E*D sia inferiore alle dimensioni del blocco da cifrare. La velocità dell'algoritmo è inversamente proporzionale al numero di 1 presenti in E: per questo è consigliabile usare un valore di E che contenga massimo tre 1, e i numeri che soddisfano questo principio sono: 3, 17 o 65.537; il primo è vulnerabile ad attacchi di tipo small exponent quindi scarsamente utilizzato.

RIPEMD è un algoritmo di hash crittografico che prevede blocchi in input da 512 bit e genere un output di 160 bit. È un algoritmo teoricamente molto buono, ma è stato scarsamente utilizzato. Buono perché sicuramente migliore degli algoritmi precedenti MD5, ritenuti poco sicuri in quanto rischiavano di generare collisioni. Non essendo però utilizzato, i matematici si sono concentrati sugli aspetti dell'algoritmo di SHA-2.

RC4. È un algoritmo di crittografia simmetrica ritenuto molto veloce in quanto viene applicato ad algoritmi stream, ovvero, viene fatto uno XOR bit a bit tra chiave e messaggio. Sorgente e destinazione devono concordare un seme da cui verrà generato un key stream di lunghezza pari alla lunghezza del messaggio da cifrare e decifrare. Si basa sulla proprietà che A XOR B = C; C XOR B = A; C XOR A = B.

21. Differenza algoritmi stream e a blocchi

Gli **algoritmi a blocchi** prevedono che un messaggio venga suddiviso in più blocchi su cui poi applicare la cifratura con la chiave simmetrica per ottenere in output un blocco di dimensione uguale al precedente. Serve per cifrare dati di grandi dimensioni. Gli algoritmi per cifratura simmetrica a blocchi sono ECB e CBC: il primo

cifra dei blocchi separatamente, avendo il vantaggio di fare operazioni in parallelo ed essendo quindi molto veloce, ma è vulnerabile ad attacchi di tipo known plaintext (blocchi uguali generano un output uguale), il secondo prova a rimediare a questi errori rendendo dipendente la cifratura del blocco precedente a quella del blocco successivo, aggiungendoci un IV iniziale per evitare che un attaccante possa far deduzioni qualora due messaggi inizino con lo stesso blocco cifrato. Se l'ultimo blocco del messaggio è minore della dimensione di un blocco normale, o si aggiunge del padding o si applicano metodi di CyphertextStealing CTS per evitare di sprecare byte.

Gli **algoritmi di stream** invece prevedono una operazione di XOR bit a bit tra il messaggio da trasmettere e un key stream, generato da un seed comune alle due parti. Il cuore degli algoritmi di stream sta nella generazione di numeri casuali PRF fatti bene. Sono molto più veloci degli algoritmi a blocchi in quanto l'unica operazione prevista è una operazione di XOR, tuttavia è consigliabile applicarli quando si ha a che fare con pochi dati in quanto la lunghezza della chiave deve essere pari alla lunghezza del messaggio. se il messaggio è lungo GB di dati non è efficiente. Gli algoritmi a stream sono RC4, Salsa20 e la sua versione aggiornata ChaCha20, che descrivono come combinare diversi valori al fine di generare un keystream valido. In particolare, in Salsa e chacha20 vengono mescolati seed, stringhe fisse e un nonce. In chacha20 questi tre valori vengono mescolati per 12 volte (8 nei sistemi: 7 è ad ora un valore di mescolamento insicuro).

22. Perché gli algoritmi di stream sono più veloci?

Gli algoritmi di stream sono molto più veloci perché l'operazione XOR è molto semplice da calcolare. Tuttavia richiedono una sincronia costante tra mittente e ricevente: basta un errore di trasmissione di un bit e tutti i dati risultarebbero corrotti. Gli algoritmi a blocchi sono molto più lenti degli algoritmi stream per via delle operazioni di suddivisione in blocchi. In particoalre, CBC è ritenuto più sicuro ma anche più lento in quanto c'è una dipendenza reciproca tra i dati che non gli permette di lavorare in parallelo.

23. Un'azienda deve scambiare con un'altra dei file ma possono utilizzare soltanto una chiave di 12 caratteri max; indicare come deve essere implementato il sistema (NOTA: volevano nella soluzione che si parlasse anche di kdf)

Innanzitutto è necessario creare una chiave usando le Key Derivation Function. Un algoritmo di KDF è PBKDF2, in cui viene messo in input un sale, una password e una Pseudo Random Function (generazione di numeri casuali) a una funzione di hash, che viene iterata C volte. Ottengo infine una chiave di dimensione dkLen. *Poi utilizzo IPSec tunnel mode sui gw aziendali per avere integrità dei dati e autenticazione del mittente. Per aver riservatezza sui dati utilizzo cyphersuite VPN-B.*

24. Un messaggio di 28 byte viene cifrato con DES-CBC: quanti byte verranno inviati in totale?

DES: prende in input blocchi da 64 bit (8 byte), usa una chiave da 56 + 8 bit di parità.

CBC: implica un IV iniziale.

Senza CTS, aggiungo un padding al blocco finale: 28/8 = 3.5 -> 4 blocchi da 8 byte (32 byte tot) + 8 byte di IV = 40 byte.

25. Se devo cifrare in modalità DES-CBC un file da 84 byte, quanti byte trasmetterò in rete?

DES ha blocchi da 64bit (8 byte), quindi 84<88/8=11 blocchi da 8 byte più un blocco delle stesse dimensioni per l'IV, in totale (11+1)*8=96 byte

26. Avendo un file da 1500 byte, se lo cifro con 3DES-CBC quanto sarà grande il file finale?

3DES ha blocchi da 64bit (8 byte), quindi 1500#8=4 byte nell'ultimo blocco che necessitano di 8-4=4 byte di padding per riempirlo, quindi in totale il file avrà dimensione 1500+4=1504byte

27. CBC vs CTR: come funzionano, vantaggi e svantaggi

CBC è un algoritmo a blocchi che prevede un'operazione di XOR tra il blocco Cn-1 e Pn, per poi venir cifrato con la chiave K e ottenere Cn. Per evitare che un attaccante possa far deduzioni sull'inizio del blocco, si implementa un IV da mettere in XOR con P0.

+ non è vulnerabile ad attacchi di tipo known-plaintext: blocchi uguali avranno cifrature diverse.
+ non è vulnerabile ad attacchi di swapping

- Algoritmo lento: non è parallelizzabile.
- Un errore di trasmissione di un blocco compromette tutto il blocco successivo.

CTR invece serve quando devo cifrare pochi dati. Se devo ad esempio cifrare un blocco da 1 byte, lo metto in XOR con il primo byte di un blocco da 16 byte cifrato (composto da nonce + un counter, che conosce anche la controparte), ottenendo C. Per decifrare quindi rieseguo lo XOR tra C e il primo byte cifrato dello stesso blocco iniziale, ottenendo il plaintext.

+ Utile per trasmettere pochi dati senza sprecare

- sincronizzazione necessaria del contatore tra mittente e destinatario: un blocco cancellato desincronizza.

28. Due utenti desiderano scambiarsi via rete una serie di documenti informato ASCII (.TXT). Suggerire quali operazioni è opportuno svolgere su questi documenti prima di trasmetterli per resistere ad attacchi sulla rete (insicura). Si tenga presente che i documenti non contengono info riservate. Nota: non si usino protocolli o formati dati complessi. Si esprima la soluzione tramite formula (usando termini appropriati, come aes(k,d) piuttosto che enc(k,d))

n=nonce+counter

k=DH

digest=hmac_sha256(k, P||n)

c=P||digest||n

29. Utente A vuole mandare un messaggio segreto e autenticato agli utenti B e C, tutti e tre hanno un paio di chiavi RSA a testa. Descrivere il formato del data block per inviare il messaggio con le richieste proprietà di sicurezza.

Bisogna cifrare con le chiavi pubbliche di B e C e firmare con la propria privata e distribuire la chiave pubblica di A, quindi:

-C riceve: AES_128(Kpub;c , M)||HMAC-SHA256(AES_128(Kpub;c , M), Kpri;a)||Kpub;a

-B riceve: AES_128(Kpub;b , M)||HMAC-SHA256(AES_128(Kpub;b , M), Kpri;a)||Kpub;a

Messaggio segreto: richiede riservatezza

Messaggio autenticato: richiede firma digitale (crittografia asimmetrica).

30. Parlare del meccanismo del keyed digest (cos'è, quando e come si usa, vantaggi e svantaggi).

Il keyed digest è un algoritmo che permette di soddisfare insieme le proprietà di integrità e autenticazione dei dati. il principio è che un messaggio da inviare questo viene concatenato alla chiave simmetrica condivisa, e su questa concatenazione viene applicata la funzione di hash. importante è ricordare che la lunghezza del digest deve essere almeno il doppio del numero di bit della chiave simmetrica presa in considerazione. In

questo modo, un MITM non può modificare il plaintext P inviando P' modificato con il relativo digest d' ricalcolato.

+ integrità: se i dati vengono modificati durante il transito tra i due canali, cambiando anche il digest relativo, il ricevente se ne accorgerà
+ autenticazione dei dati, per via della chiave simmetrica.
+ algoritmo veloce da eseguire essendo algoritmo di hash
+ quantità di dati trasmessi bassa
+ un singolo algoritmo garantisce insieme due proprietà

- integrità parziale per via delle collisioni che possono causare algooritmi di digest.
- non ripudio: non essendoci firma digitale non è garantita questa proprietà di sicurezza.
- i dati vengono spediti in chiaro, non vengono cifrati.

31. Parlare del keyed-digest e la firma digitale, quali sono le proprietà che offrono, vantaggi e svantaggi?

Il keyed-digest è un algoritmo che permette di fornire insieme autenticazione dei dati e integrità: il digest viene calcolato a partire infatti da una concatenazione di dati da spedire e chiave simmetrica. Ha come vantaggio quello di essere un algoritmo molto veloce in quanto le funzioni di hash sono molto veloci, e di dimensioni ridotte. Di contro non garantisce il principio del non ripudio non essendoci firma digitale, e può avere problema di collisioni.

Nella firma digitale invece viene garantito il principio di non ripudio. Il digest viene cifrato con la chiave privata del mittente. La firma viene mandata insieme al digest in una struttura dati apposita, chiamata X.509. Il ricevente decifra il messaggio con la chiave pubblica del mittente, e se il digest calcolato da lui corrisponde con il digest decifrato, si soddisfano le proprietà. Riassumendo:

+ integrità: i messaggi in chiaro se vengono modificati il ricevente se ne accorge
+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente.
+ pochi dati inviati

- riservatezza: i dati vengono inviati in chiaro
- non applicabile a un flusso di dati in real time perche gli algoritmi a crittografia asimmetrica sono molto pesanti computazionalmente

32. Un'azienda vuole fare firma digitale su tutti i suoi documenti e conservare sia i documenti sia le firme in modo da poterli verificare anche in futuro. Che cosa usare? Che cosa deve memorizzare insieme alla firma?

Una enveloping CMS, contenente le varie firme associate a un dato documento e i corrispettivi certificati, più aggiornamento costante delle CRL associate alle varie firme possedute per verificarne la validità

33. Quali proprietà di sicurezza offre la firma digitale, come si realizza, quali parti della firma offrono quelle proprietà di sicurezza.

La firma digitale serve a risolvere il problema principale dei keyed digest: il keyed digest infatti non garantisce il principio del non ripudio. Per questo motivo, si usa la firma digitale, che consiste nel cifrare con la propria chiave privata il Message Digest, inviare sia il digest sia un certificato di firma digitale contenente chiave pubblica del mittente. In questo modo, lato ricevente, si verifica che il digest ricevuto sia uguale a quello calcolato da lui. In sostanza:

- Mittente, firmatario: H = enc(S_Kpri, hash(M))
- Trasmissione: M || H
- Verificatore: X = dec(s_kpub, H)

- If(X == hash(M)) then OK else ALARM.

34. Perché l'algoritmo SHA-1 è deprecato? Suggerire una possibile e valida alternativa e motivare perché questa sia migliore di SHA-1.

L'algoritmo SHA-1 è un algoritmo di digest, che prendeva in input dati da 512 bit e restituiva in output un digest da 128 bit. È un algoritmo deprecato dal 2005 perché: dato il dominio dei Message Digest e il dominio dei Digest, definendo n = numero di bit dei Message Digest (128 in questo caso), è stato dimostrato che muovendomi nel dominio di M in uno spazio di dimensioni n/2 riesco facilmente a trovare 2 messaggi che abbiano lo stesso digest, e che generino dunque collisione. In questo caso la procedura anziché 2^80 tentativi per trovare un digest uguale per due messaggi, ne basterebbero 2^69, 2000 tentativi in meno. Per questo motivo è stato diffuso SHA-2, un'alternativa a SHA-1, che si basa sullo stesso principio ma di cui è stato aumentato il blocco di output, da 128 a 512 nel caso di sha-512, 224 nel caso di sha-224 etc. La tendenza è andare verso SHA-3, su cui si sta ancora lavorando, che non parte dal principio di SHA-1 e SHA-2: è stato aggiunto uno spazio tridimensionale in cui lavorare, che si comportava bene in hardware.

35. Ordinare dal più veloce al più lento i seguenti algoritmi: SHA, AES_ECB, AES_CBC, RC4

1. SHA= algoritmo di hash, molto veloce. 2. RC4= algoritmo di stream, più veloce. 3. AES_ECB = algoritmo a blocchi parallelizzabile. 4. AES_CBC= algoritmo a blocchi non parallelizzabile.

36. Dati i seguenti algoritmi di cifratura, ordinarli dal più lento al più veloce: AES, DES, RC4, 3DES.

3DES, DES, AES, RC4

3DES, DES: sono algoritmi che necessitano di permutazioni quindi hanno bisogno di un hw dedicato.

AES: algoritmo di cifratura più sicuro e più veloce perché non ha più le operazioni di permutazione.

RC4: algoritmo di stream, il più veloce di tutti.

37. Descrivi la crittografia a curve ellittiche.

Nella crittografia asimmetrica a curve ellittiche non si lavora in aritmetica lineare modulare ma in uno spazio bidimensionale a curve ellittiche, in cui le operazioni permesse sono somma e prodotto con uno scalare. Le operazioni in questo caso sono più complicate, dato che il problema del logaritmo discreto su una curva è più complesso da risolvere per un attaccante rispetto al problema del logaritmo discreto su aritmetica modulare, di conseguenza posso ridurre la dimensione delle chiavi da 1024-2048 a 160-256.

Concettualmente parlando, i valori validi sono i punti che soddisfano l'equazione di una curva ellittica. Se voglio applicare l'algoritmo di DH con le curve ellittiche, P anziché essere un numero arbitrario è una curva ellittica decisa in accordo da A e B, definisco G come un punto della curva. A sceglie arbitrariamente il valore x e calcola X = xG, B sceglie arbitrariamente il valore y e calcola Y = yG. A e B scambiano X e Y, tenendo segreti x e y. A questo punto, A calcola K = xY, B calcola K = yX, quindi K = xyG.

Sono curve ellittiche molto utilizzate per le IoT, perché occupavano meno silicio rispetto alle DSA normali.

Gli algoritmi sono: **ECDSA** (Ellittic Curve Digital Sign Authentication) per firma digitale, **ECIES** (ellittic curve Integrated Encryption Scheme) per generazione di chiavi crittografiche simmetriche

38. Dire i due principali vantaggi degli algoritmi basati su ECC

Le EC sono curve ellittiche, significa che anziché lavorare in uno spazio modulare monodimensionale si lavora in uno spazio bidimensionale a curve ellittiche in cui i valori accettabili sono i punti che soddisfano l'equazione di una curva ellittica.

- Vantaggio1: il problema del logaritmo discreto diventa più complicato in questo campo, per cui le chiavi passano a una dimensione di 160-256 bit
- Vantaggio2: le operazioni da fare sono elementari, e danno come risultato dei punti
- Vantaggio3: occupano meno silicio se implementate in hardware, quindi si prestano bene per essere usati nelle IoT

39. Descrivi l'algoritmo di keyed-digest CBC-MAC.

MAC (Message Authentication Code) permette di avere insieme le proprietà di integrità e autenticazione. CBC è un algoritmo a blocchi di crittografia simmetrica, e permette di ricavare tanti blocchi cifrati dipendenti gli uni dagli altri per evitare di essere vulnerabili ad attacchi di known plaintext, swapping. Gli algoritmi di keyed digest si basano sul fatto che venga fatto l'hash di una concatenazione di dati e chiave simmetrica conosciuta da entrambe le parti, in modo da esser immune ad attacchi che modificano messaggio e digest mandando questi ultimi. Il CBC-MAC in sostanza consiste nel calcolo del MAC sfruttando l'algoritmo CBC, in particolare, il vettore di inizializzazione è nullo e fisso dato che non è necessaria la riservatezza. I blocchi cifrati vengono buttati via eccetto l'ultimo, che è considerato il MAC. In questo modo per chi decifra, compara l'ultimo blocco di testo decifrato con quello ricevuto e verifica che questi siano uguali.

40. Uno dei primi metodi per criptare i dati?

Uno dei primi metodi utilizzati per cifrare i dati è stato ECB, ossia un algoritmo a blocchi a cifratura simmetrica che prevedeva le seguenti fasi:

- Suddivisione del Plaintext in blocchi di dimensione fissa
- Aggiunta di padding sull'eventuale ultimo blocco qualora non fosse completato s enon si usano tecniche di CTS
- Applicare ad ogni blocco l'algoritmo di cifratura, indipendentemente dagli altri: Ci = enc(K, Pi)
- Concatenare i blocchi risultanti per produrre il testo cifrato.

Per decifrare si faceva l'operazione inversa, ossia: Pi = dec(K, Ci)

È un algoritmo obsoleto perché soggetto ad attacchi di tipo swapping e known-plaintext.

41. Su sistemi embedded spesso si preferisce ECDSA rispetto a RSA: perché?

Si usa il sistema ECDSA perché se viene ottimizzato in hardware utilizza meno silicio di un DSA normale, in quanto le chiavi sono estremamente più corte (sull'ordine dei 160-256 bit contro i 1024-2048), per un livello di sicurezza comparabile.

42. Qual è il principale vantaggio della modalità di cifratura CTR?

Gli algoritmi di tipo CTR servono sostanzialmente per cifrare N bit alla volta, tendenzialmente quando N è minore della dimensione del blocco. Si concatenano un nonce e un contatore, si prende una dimensione N di questa stringa concatenata e si mette in XOR con il plaintext P. Vantaggi:

- Procedura altamente parallelizzabile, quindi molto veloce
- Gli errori non vengono propagati

43. Indicare quale attacco all'integrità è possibile se dei dati D vengono protetti con un MAC calcolato nel seguente modo (k è la chiave e h è la funzione di hash): MAC =h (k || D).

Questo tipo di calcolo di MAC è soggetto ad attacchi di estensione: un attaccante potrebbe infatti concatenare a D altri messaggi inseriti da lui, ricalcolando il digest. Il ricevente troverà una corrispondenza tra digest calcolato e digest ricevuto, non si accorgerà della manomissione.

44. Vantaggi e svantaggi di cifratura fatta con enc(enc(p, k1), k2) con k1 e k2 chiavi diverse ma di lunghezza uguale

Una cifratura fatta in questo modo con due chiavi diverse corrisponde alla cifratura proposta dall'algoritmo 2DES: questo algoritmo è infatti stato quasi subito scartato. In sostanza, è soggetto ad attacchi di tipo known-plaintext chiamato meet-in-the-middle, che permette di fare delle congetture: in sostanza, se un attaccante conosce sia il plaintext sia il cyphertext può trovare la chiave eseguendo 2^{N+1} tentativi (N= lunghezza delle chiavi). quindi, per il doppio sforzo computazionale, viene garantito solo il doppio del livello di sicurezza. per questo motivo non è stato mai preso in considerazione, e si è passati direttamente al 3DES.

45. Descrivere la tecnica crittografica ECB identificandone vantaggi e svantaggi.

ECB è stato uno dei primi modi per fare crittografia asimmetrica a blocchi. Dato un algoritmo di crittografia asimmetrica a blocchi che necessita di blocchi d B byte, prima di tutto

- Suddivido il plaintext in tanti blocchi lunghi B byte
- Aggiungo eventuale padding sul blocco finale qualora non raggiungesse B byte
- Applico ad ogni blocco la cifratura: Ci = enc (K, Pi) con K = chiave simmetrica
- Concateno i blocchi ottenuti per produrre il testo cifrato.
- Per decifrare inverto: Pi = dec(K, Ci)

+ Non ho propagazione degli errori perché i blocchi sono indipendenti
+ parallelizzazione delle operazioni tra i vari core

- attacchi di swapping
- attacchi knownplaintext, dato che messaggi uguali hanno in output lo stesso cyphertext un attaccante può facilmente fare deduzioni del testo.

46. Quale delle seguenti tecniche – firma digitale, cifratura simmetrica, keyed-digest –sarebbe da preferire per proteggere l'integrità di un flusso di pacchetti a 1 Gbps? Giustificare la scelta.

Firma digitale è troppo lenta, cifratura simmetrica non comprende la proprietà di integrità, di conseguenza è consigliabile usare keyed-digest perché si basa su operazioni di hash estremamente veloci e versatili per questa trasmissione.

47. Quale tecnica è meglio usare per proteggere dati trasmessi in rete da attacchi di tipo replay? Cifratura simmetrica, cifratura asimmetrica, keyed-digest, altro? Giustificare.

Per difendersi da attacchi di tipo replay è necessario soddisfare la proprietà di integrità, quindi uso un keyed digest basato su chiave simmetrica preconcordata con la controparte. L'operazione da fare è:

d = kd(K || n || M || K) (digest) -> invio M || n || d

inserisco le chiavi all'inizio e alla fine nel digest per evitare attacchi prefix ed estension.

48. Due utenti devono scambiarsi dei file di testo formato ASCII (txt) non riservati. Come fanno a garantire che non vengano modificati durante il transito? Spiegare quali funzioni di sicurezza usare e enunciare la formula che produce il documento X trasmesso rispetto al documento originale. Si usino nomi significativi (es. aes(K,D) rispetto a enc(K,D).

- **K_{AB} = DH**. Genero la chiave K utilizzando l'algoritmo di Diffie Hellman, per avere la chiave segreta condivisa. (ricordiamo che DH serve per scambiarsi chiavi simmetriche, in particolare, viene prima deciso un numero P arbitrario e un generatore G < P. A inventa x e calcola A = G^x %P , B inventa y e calcola B = G^y%P. A e B vengono trasmessi reciprocamente, A calcola K = B^x % P, analogamente B. In questo caso così le chiavi sono uguali, e un attaccante per conoscerla ha bisogno di trovare x o y mediante logaritmo discreto).

- **D = HMAC_SHA256(K_{AB},M)**: creo il message digest per avere le proprietà di integrità e autenticazione.
- **Dati inviati**: X = M || D

49. Si deve trasmettere cifrata una password da 12 caratteri con 2 byte di sale con AES. Cosa si usa tra ECB, CBC e CBF?

CBF (ma non lo abbiamo studiato, ignorare)

50. Dovendo cifrare con AES una password da 12 caratteri con 2 byte di sale è meglio usare ECB, CBC o CTR?

Aes ha un blocco da 128 bit, 12 caratteri ascii quindi da 8 bit ciascuno sono 96 bit più 16 bit di sale sono 112 bit, quindi inferiore al blocco, il che mi porterebbe a usare CTR

51. Firma digitale con digest SHA256, chiave privata RSA-2048 su un file da 10MB. Qual'è la dimensione della firma?

Poiché viene utilizzato una chiave privata RSA-2048 la dimensione della firma sarà 2048bit

52. Come possono inviarsi un file due tizi che condividono una password

Tramite algoritmi a chiave simmetrica, usando la password come chiave a cui aggiungo il sale per rendere la distribuzione più uniforme, e applico una Key Derivation Function. Posso usare ad esempio l'algoritmo PBKDF2 che prende in input password + sale + PRF, itera C volte e ottiene in output una chiave K di dkLen byte.

53. Si deve firmare un documento da 10 MB con digest SHA-1 e chiave RSA. Quanto è grande esattamente la firma del documento?

Dipende dalle dimensioni della chiave RSA. Ipotizzando che sia di 2048 bit, la firma sarà lunga 2048 bit

54. Quali algoritmi si possono usare per scambiare chiavi segrete?

Quelli a chiave asimmetrica (come RSA), dato che non si deve inviare nessun segreto per farli funzionare

55. Hash per calcolare la password partendo da un seme.

Si usa una funzione PRF, Pseudo Random Function, una funzione di hash che deve essere fatta bene per gli algoritmi di tipo keystream.

56. Per quale applicazione è stato inventato il CTS?

La tecnica del ciphertext stealing (CTS) permette di usare gli algoritmi a blocchi in modalità ECB o CBC senza ricorrere al padding in quanto avviene uno switch tra blocco n-1 e blocco n, a cui è stato aggiunto un pezzo di n-1.

57. Spiegare cos'è la modalità operativa CTS qual è l'idea principale su cui si basa la sua implementazione e perchè sta assumendo sempre più rilevanza

Dipende dall'algoritmo. In ECB viene cifrato Cn = Pn || tail(Cn-1) ; e si scambiano Cn di dimensione pari alla dimensione del blocco e Cn-1 di dimensione blocco – tail. (tail è la dimensione per fare arrivare Pn a B)

In CBC a Pn viene aggiunto un padding di 0, viene fatto Cn = enc(K, Pn XOR Cn-1) e si scambia l'ordine di invio analogamente a prima.

In sostanza quindi, al posto di aggiungere del padding standard, si aggiunge un pezzo pari alla dimensione del blocco mancante al blocco n-esimo, si cifra il blocco così composto e si scambiano Cn e Cn-1, con Cn-1 di dimensione ridotta.

Sta prendendo rilevanza perché è un algoritmo che permette di non aggiungere dati inutili all'ultimo blocco risparmiando dati.

58. Perché non si usa 2DES e si preferisce 3DES?

2DES corrisponde all'esecuzione di 2 blocchi DES in cascata. Il problema è che è soggetto ad attacchi known-plaintext del tipo Meet in the middle: un attaccante infatti che conosce sia P sia C, può costruirsi una tabella di 2^56 possibili chiavi per P -> DES -> C' e analogamente una tabella di 2^56 chiavi per C' <- C. in questo modo provando tutte le chiavi da entrambe le parti, può trovare la chiave in $2^* 2^{57}$ tentativi, ossia, doppio carico computazionale -> solo il doppio livello di sicurezza. il 3DES invece ha una sicurezza più elevata di circa 2^{112} bit per il triplo carico computazionale, quindi è più accettato.

59. Calcolare quanti dati devono essere salvati su disco per eseguire la decifratura e l'autenticazione di un file grande 1 kB con digest SHA-1 e chiave RSA 1024 bit.

1024 Byte di file + 20 Byte di digest + 128 byte RSA

60. Quali algoritmi base (non strutture dati complesse) si possono utilizzare per garantire riservatezza di un file situato su un server di cui non ci si fida?

61. Spiegare il termine security through obscurity. Spiegare perché alcuni dicono sia buono ed altri no.

Questo meccanismo implica che qualcosa si ritiene sicuro qualcosa per il principio che questa cosa è segreta, come possono essere algoritmi o metodi. Non è un principio che può essere usato come sicurezza aziendale: la progettazione o costruzione di un meccanismo di sicurezza andrebbero rese pubbliche anche per trovare eventuali bug a riguardo. La cosa importante è mantenere segrete le chiavi.

62. Spiegare la authenticated encryption.

Gli algoritmi di AE mettono in un'unica operazione le operazioni di crittografia e keyed digest. Quindi, in un'unica operazione si assicurano integrità e riservatezza, con un solo algoritmo e una sola chiave. passo i parametri necessari per integrità (K, IV) e per riservatezza (K) e ottengo in output una struttura dati composta da C e MAC. È un algoritmo quindi molto veloce, con minor rischio di errore di implementazione.

Gli algoritmi AE sono:

- **AEAD** (associated data) in cui si può decidere che alcuni dati possono essere non criptati (come l'header di un IP) ma solo con integrità e autenticati.
- Single pass o double pass: un algoritmo single pass non ha bisogno di memorizzare i risultati della prima passata per ulteriori calcoli (calcolo istantaneo di C e MAC), il double pass sì ed è più lento se implementato in sw.
- On line o off line: i dati devono essere salvati (offline) o presi direttamente.

Gli algoritmi sono:

- GCM (online single pass AEAD)
- OCB (online single pass AEAD)
- EAX (online double pass)
- CCM (offline double pass)

63. CBC e CTR mode: spiegare, vantaggi e svantaggi.

CBC è un algoritmo a blocchi che parte da un IV e fa operazioni seriali tra blocco N e blocco N-1 per far sì che i blocchi siano dipendenti gli uni dagli altri per evitare i problemi degli ECB. Sono quindi più

sicuri da attacchi di swapping e known plaintext, ma di contro hanno propagazione degli errori e no parallelizzazione.

CTR invece trasmette file a dimensioni inferiori a quelle di un blocco. Ha bisogno di un nonce e un counter da mettere in XOR col plaintext (scarto le parti che non arrivano alla dimensione del blocco). Ha bisogno di sincronizzazione tra mittente e ricevente che può mancare se un blocco viene cancellato.

64. Qualcuno ti ha inviato un file firmato digitalmente con RSA e SHA-. . . , insieme al certificato del firmatario e al certificato della sua CA. Descrivere come validare la firma, identificare le informazioni richieste ed ottenere l'accesso ad esse.

Validare la firma: per verificare la validità di un certificato, ho bisogno di sapere se quest'ultimo è scaduto o meno. Ho quindi bisogno di accertarmi che questo sia valido. Quindi cerco il CA da cui è stata estratta la chiave pubblica e verifico se è scaduto o meno controllando nella CRL. Se non è presente significa che nell'ultimo mese almeno quel certificato è valido (eventualmente chiedo a OCSP per sapere se attualmente è valido). Dopo aver constatato che la firma proviene da un certificato valido, decifro con la kpub il valore del KD. Successivamente calcolo il keyed digest con la Ksimm e hash del plaintext, e verifico se calcolato = ricevuto.

65. Descrivere DH, i suoi problemi e le soluzioni ad essi.

DH è un metodo per concordare una chiave simmetrica. Gli step da seguire sono:

- Si decide pubblicamente un valore P e un generatore G<P
- A inventa x e calcola X = G^x % P, B inventa y e calcla Y = G^y % P.
- A riceve Y da B e calcola KA = Y^x % P; analogamente B riceve X e calcola KB = X^Y % P
- Ma KA = KB perché $Y^x = G^{(Y*X)\%P}$ e $X^y = G^{(X*Y)\%P}$ quindi sono equivalenti e KA=KB=K

Problema attacco man in the middle: un attaccante può inserirsi nella comunicazione e sniffare i dati inviati tra A e B, e inserendo delle chiavi calcolate da lui. Quindi un attaccante calcola Z = G^z % P e manda questa informazione sia ad A, che può vederla come Y, sia a B, che può vederla come X. in questo modo l'attaccante può sniffare tutti i dati usando un processo di preautenticazione:

- Certificati per le chiavi DH
- Protocolli autenticati

66. RSA, RC4, SHA-1, . . . : qual è l'intruso e perché?

sha1 perché è un algoritmo di digest mentre gli altri di cifratura

67. Spiegare brevemente la tipologia di cifratura simmetrica e quella asimmetrica, indicando i vantaggi e svantaggi di ciascuna tipologia.

Cifratura simmetrica: la chiave è condivisa da mittente e destinatario, le operazioni sono invertibili (C = enc(P, K), P = dec(C, K). È un algoritmo veloce e ha una generazione di chiavi semplice. Purtroppo necessita della distribuzione delle chiavi simmetriche, quindi ho bisogno di un algoritm a chiave pubblica.

Gli algoritmi a chiave pubblica hanno una chiave pubblica e una chiave privata, e le chiavi hanno una relazione matematica tra loro. tendenzialmente si parla di firma digitale se faccio enc(Kpri, P) e dec(kpub, C) e garantisce autenticazione della controparte con non ripudio, invece si parla di riservatezza de dati se faccio enc(Kpub, K) e dec(Kpri, C) e serve di solito per scambiarsi chiavi simmetriche. È un'operazione molto più lenta infatti di solito si lavora su dati piccoli perché le operazioni sono complicate e avvengono su numerosi bit.

Capitolo 3- Sistemi di autenticazione

68. Sistemi di autenticazione a sfida simmetrici, vantaggi e svantaggi.

Un sistema di autenticazione a sfida simmetrica implica che Claimant e Verifier posseggano una **chiave segreta condivisa**. Gli step sono:

- Identificazione: un Claimant contatta un verifier mandando il proprio ID.
- richiesta di una prova: Il verifier in seguito manda una sfida, in particolare genera un Nonce e lo invia al claimant
- prova: Il Claimant risponde alla sfida con *response = f(Nonce, Ksimm).* Spesso si usa keyed-digest: response = kd = H(k, Nonce)
- Controllo: il verifier verifica se la response ricevuta è uguale a quella che si è calcolata lui, e in caso positivo il claimant è autenticato: if (response == H(K, Nonce)) OK else ALARM.

+ immune allo sniffing
+ immune agli attacchi replay per via del nonce

- lato verifier, deve memorizzare la chiave in chiaro. Un attacco al DB sarebbe quindi disastroso. Si può risolvere usando SCRAM.
- il client deve avere una funzione di hash per calcolare la risposta.
- implica uno scambio di chiavi simmetriche mediante crittografia asimmetrica.

69. Kerberos è detto essere un sistema di autenticazione TTP. Spiegare perché è classificato in questo modo e quale rischi corrono i client ed i server applicativi se il terzo non si comporta correttamente.

TTP significa Third Trusted Party. Questo significa che la comunicazione tra due entità, spesso Client e Server, si affida a un servizio terzo che garantisce autenticazione da entrambe le parti. In particolare, Kerberos è definito in questa maniera in quanto composto da due entità esterne a client e server, ossia, Autentication Server AS (che contiene le chiavi dei client Kc e le chiavi del TGS) e Ticket Granting Server TGS che mantiene invece le chiavi dei server. AS autentica il client, TGS autentica il server. I vantaggi di questo metodo sono che client e server non devono memorizzare delle chiavi, a conoscerle sono infatti TFS e AS. Introducendo di fatto il concetto di ticket, non è neanche necessario riautenticarsi ogni volta, in quanto questi ticket hanno una loro durata e validità.

70. Spiegare cos'è l'attacco dizionario: sotto quali ipotesi può essere condotto e quali contromisure adottare.

Un attacco di tipo dizionario è un tipo di attacco forza bruta che un attaccante esegue quando è riuscito a rubare un database di password non memorizzate in chiaro ma di cui è stato memorizzato l'hash relativo. Avendo accesso a queste informazioni, viene fornita dal Dark Web una lista contenente tutte le password più comuni e più frequenti da utilizzare.

Se l'attaccante conosce l'algoritmo di digest utilizzato per calcolare l'hash della password, può calcolare il digest di tutte le password di questa lista e infine fare una query al database rubato per verificare se c'è corrispondenza tra password presenti nel database e quelle calcolate da lui. In caso affermativo, è anche possibile verificare se altri utenti hanno utilizzato la stessa password o se l'utente ha usato in più servizi la stessa password.

Per evitare questo tipo di attacco, spesso si concatena la password a un sale (un valore randomico nonce) e successivamente ne si calcola l'hash. questo rende questo tipo di attacco non così facile da eseguire. In questo modo un attaccante dovrebbe cenerare un database per ogni numero random diverso, rendendo questo tipo di attacco impraticabile.

71. Confrontare le tematiche di autenticazione a sfida simmetrica ed asimmetrica identificando chiaramente vantaggi e svantaggi di ciascuna di esse.

Un sistema a sfida simmetrico prevede che Claimant e Verifier posseggano una chiave segreta condivisa, mentre un sistema a sfida asimmetrico prevede un'autenticazione a chiave pubblica.

- **CRA simmetrica**: Claimant manda il proprio ID (es: 1), Verifier genera un nonce da mandare al claimant. Il claimant calcola response = keyed-digest = H(Nonce, K1) e la spedisce al Verifier. Il Verifier verifica se response == H(Nonce, K1) con K memorizzata da lui. In caso positivo, il claimant è autenticato.
- **CRA asimmetrica**. Il claimant manda al verifier il proprio certificato contenente la chiave pubblica. Il verifier genera un Nonce e lo cifra con la Kpubblica ricevuta. Il claimant calcola Response = dec(Nonce, Kpri) con la propria chiave privata e lo spedisce al Verifier, che verifica se nonce ricevuto e nonce calcolato coincidono.

CRA simmetrica

- verifier deve memorizzare le chiavi dei claimant in chiaro per poterne fare l'hash: un attacco al DB sarebbe fatale
- necessita dello scambio dei chiavi simmetriche;
- challenge mandata in chiaro.

+ procedura più veloce perché è necessario fare solo le operazioni di hash.

CRA asimmetrica è

+ più sicura di quella simmetrica (usata per Ipsec, TLS) e non richiede memorizzazione da parte del Verifier delle chiavi.
+ la sfida trasmessa è cifrata

- più lenta (per l'encription da parte del verifier), e quindi soggetta ad attacchi DoS se un attaccante sniffa ID validi, mandando tante richieste a nome di quell'ID).

Entrambe proteggono da attacchi di sniffing (non è possibile risalire alla Ksimm o Kpri) e reply (per via della generazione del nonce).

72. Cos'è una rainbow table?

Le rainbow table sono database speciali precalcolati che permettono di raggiungere un compromesso tra:

• **memoria**: solo un sottoinsieme degli hash è salvato nel database precalcolato

• **tempo di calcolo**: quando la catena viene trovata, occorre ripercorrere la catena per trovare la password

73. Spiegare il metodo della sfida asimmetrica elencando punti di forza e deboli del metodo e dei singoli componenti che partecipano.

Un sistema a sfida asimmetrica è un processo di autenticazione che verifica un'identità in seguito alla verifica del fatto che il claimant risponda correttamente a una challenge inviata. Si basa sulla crittografia a chiave pubblica, cioè, il claimant deve possedere un certificato rilasciato da una CA. La procedura è la seguente:

- Claimant C manda il proprio certificato contenente la chiave pubblica al verifier V.
- V -> challenge = enc(Nonce, Kpub(C)) con Nonce generato da V, e la invia al claimant C
- C -> response = dec(Nonce, Kpri (C)) e la invia al Verifier
- Verifier verifica se Response == Nonce. If sì OK else ALARM

+ La sfida trasmessa è cifrata.

+ Non richiede memorizzazione delle K da parte del Verifier : più sicuro di simmetrica.

+ no sniffing (per la kiave) né reply (per il nonce)

- complessità computazionale lato client

- encription lenta: possibilità di attacchi DoS per attaccanti che sniffando ID validi mandano continuamente richieste di autenticazione.

- Firma involontaria da parte di un claimant se si mette un MITM nella comunicazione e si traveste da Verifier: al posto di mandare un Nonce cifrato, manda un hash di un documento da firmare. Visto che firmare, cioè cifrare con chiave privata equivale a decifrare con chiave privata, un claimant può cedere involontariamente firme. Evitabile se uso strutture date apposite.

- problemi di PKI, evitabili se il verifier memorizza la Kpubblica.

74. Spiegare che cosa è un sistema OTP time-based, indicando quali informazioni vengono trasmesse dal client al server di autenticazione e quale funzionalità è associata a ciascuna informazione trasmessa.

Nelle OTP time-based la password dipende da due fattori, ovvero: tempo e segreto Sid dell'utente, che ha memorizzato anche il verifier.

- Il verifier invia una sfida al Claimant chiedendogli di autenticarsi.
- Il Claimant come response gli fornisce il proprio ID e X = Hash(T, Sid)
- Il verifier verifica se l'X ricevuto è uguale a quello calcolato da lui, controllandolo per tre finestre temporali: IF(X == H(T-1, SiD) || X == H(T, Sid) || X == H(T+1, Sid)) OK ELSE ALARM.
- Il controllo si fa sulle 3 finestre temporali perché è possibile che il T del Claimant sia lievemente desincronizzato con quello del Verifier, e potrebbe capitar in un range più vasto. Si noti che se la sincronizzazione è tale da far ricadere T in un range maggiore, il sistema di autenticazione dve essere cambiato.

+ Sistema veloce, i tre calcoli vanno fatti su una funzione di Hash
+ le password possono essere utilizzate una sola volta, se un attaccante la sniffa non può entrare se l'user è riuscito a entrare per primo.

- il DB deve contenere il segreto dell'utente
- una sola autenticazione per time slot: non va bene per servizi con accesso ripetuto
- necessità di sincronizzare il clock tra server e client
- attacchi MITM nella comunicazione dell'orario tra Time Server e Claimant / verifier: lato claimant "porto in avanti il tempo" lato verifier lo sposto indietro.

75. Spiegare brevemente il concetto di OTP e quale problema di sicurezza risolve. Spiegare, quindi, con l'ausilio di appropriate formule, le fasi di inizializzazione e verifica nel protocollo S/KEY.

Per OTP si intende One-Time-Password, significa in sostanza la generazione di password da utilizzare una volta sola per potersi autenticare. Idealmente un cliente ha una lista di N password, quando voglio autenticarmi a un server, lui mi chiede di mostrargli la password numero X. Verifica se quella ricevuta è uguale a quella memorizzata e in caso affermativo il client è autenticato. Parallelamente, la password X viene cancellata. Risolve il problema di sicurezza dello sniffing, è soggetto a MITM se un attaccante si inserisce nella comunicazione client-server spacciandosi per server, che si può risolvere con un sistema di autenticazione del server.

Il protocollo S/KEY è un protocollo di OTP.

- Client precalcola N password nel seguente modo: P1= Hash (Segreto S); P2 = Hash (P1), …, Pn = Hash(Pn-1).

- Client manda Pn a server, che lo memorizza.

- Quando faccio login mando al server X = Pn-1.
- Il server: Hash(Pn) == Pn-1 OK else ALARM. Se OK, allora memorizza Pn-1 e scarta Pn.
- Itero la procedura fino ad arrivare a P1.

S/KEY quindi definisce un metodo di distribuzione delle OTP senza che il server conosca il segreto del client.

76. Spiegare come funziona il timestamp (sicuro).

Claimant e Verifier sono sincronizzati grazie a un TS server, che fornisce l'orario esatto a entrambi. Un attaccante tuttavia può inserirsi nella comunicazione e fare da finto time server, mandando al client un'orario successivo a quello attuale generando OTP che andranno bene nel futuro; viceversa se si immette nella comunicazione Server – TS, manda un orario precedente.

Capitolo 4

Lo standard X.509, le PKI ed i documenti elettronici

77. Dato un certificato X.509 spiegare quali sono le sue proprietà di sicurezza intrinseche e come sono ottenute.

Autenticazione e integrità tramite la firma della CA e la lista degli algoritmi usati per firmare.

78. Cos'è un certificato X.509? Elencare gli attributi.

X.509 è un certificato a chiave pubblica, ovvero una struttura dati usata per legare in modo sicuro una chiave pubblica ad alcuni attributi; permette di distribuire le chiavi pubbliche per usare le firme digitali in modo sicuro: la chiave pubblica del mittente non è fornita dal mittente, ma è fornita da un'entità esterna fidata attraverso un certificato a chiave pubblica, altrimenti un attaccante potrebbe spacciare la sua chiave pubblica come la chiave pubblica del mittente legittimo.

Un certificato X.509 versione 3 contiene, oltre alla firma digitale della CA, una sequenza di 10 elementi di dato, tra cui:

1. version: è la versione della codifica del certificato (= versione dello standard X.509 −1);

2. serialNumber: è un numero intero assegnato dalla CA, univoco per ogni certificato emesso da una CA data (cioè il nome dell'emettitore e il numero di serie identificano un certificato univoco);

3. signature: contiene l'identificativo di algoritmo dell'algoritmo e della funzione di hash usati dalla CA nella firma del certificato (ad es. sha1WithRSAEncryption);

4. issuer: è il **distinguished name** (DN) che identifica l'entità che ha firmato ed emesso il certificato (ad es. countryName=IT, stateOrProvinceName=Torino, organizationName=Politecnico di Torino, commonName=CA di prova);

5. validity: è l'intervallo di tempo, compreso tra notBefore e notAfter, in cui era valida la chiave privata corrispondente alla chiave pubblica che sta venendo certificata;

6. subject: è il DN che identifica l'entità associata con la chiave pubblica che sta venendo certificata (ad es. commonName=Antonio Lioy);

7. subjectPublicKeyInfo: trasporta il valore in chiaro della chiave pubblica che sta venendo certificata, e identifica l'algoritmo di cui questa chiave pubblica è un'istanza (ad es. rsaEncryption: esponente pubblico e modulo);

10. extensions (facoltativo): contiene eventuali estensioni specifiche del certificato.

79. Algoritmi a chiave simmetrica.

Nella crittografia simmetrica (o crittografia a chiave segreta), la chiave simmetrica è una chiave unica *K*, sia per la criptazione sia per la decriptazione, condivisa solo tra il mittente e

il ricevente. La crittografia simmetrica richiede un carico di elaborazione minore rispetto alla crittografia asimmetrica, ed è quindi particolarmente adatta per criptare grosse quantità di dati.

Gli algoritmi simmetrici si suddividono in due classi:

• algoritmi a blocchi (ad es. DES, IDEA, RC2, RC5, AES): suddividono i dati da criptare in blocchi di eguale dimensione, quindi elaborano un blocco alla volta;

• algoritmi di tipo stream (ad es. RC4, SEAL): sono in grado di operare su un flusso di dati, un bit o un byte alla volta.

80. Lei riceve una penna usb contenente un file che deve passare ad un destinatario. Poiché i due peer la ritengono una persona non fidata il mittente calcola anche un digest per proteggere il file contro le modifiche e lo trasmette direttamente al destinatario. È noto che il digest venga calcolato prendendo i 24 bit più significativi dell'hash sha256 del file. Proponga una tecnica per modificare il file senza che i peer se ne accorgano e fornisca anche una stima del numero di operazioni necessarie.

Birthday attack, con un lowerbound di 2^(24/2) = 2^12 hash parto col 50% di probabilità di trovare una hash che fa collisione

81. Descrivere la tecnica della firma digitale ed elencare tutte le funzionalità di sicurezza offerte da essa, identificando quale componente del processo firma/verifica è fondamentale per le singole funzionalità. Spiegare anche il ruolo di un certificato X.509 in questo contesto.

Nella firma digitale viene calcolato un digest con un algoritmo crittografico e associato con un oggetto di dati in modo tale che qualsiasi destinatario dei dati può usare la firma per verificare l'origine e l'integrità dei dati

Proprietà di sicurezza:

+ integrità: se i dati in chiaro vengono modificati, il digest md*R* calcolato sui dati ricevuti sarà diverso dal digest md*F* ricevuto e decriptato;

+ autenticazione: solo chi conosce la chiave privata può aver generato una firma digitale corrispondente ai dati;

– riservatezza: i dati sono inviati in chiaro;

+ non ripudio: il mittente non può negare di aver firmato i dati, a patto che la sua chiave pubblica sia fornita da un certificato a chiave pubblica.

Nel contesto delle firme digitali, un cetificato X.509 serve per determinarne la validità e distribuirne la chiave pubblica associata in maniera autenticata.

82. Come avviene la verifica di un documento firmato?

- Verificare che il certificato sia nel periodo di validità (campi notBefore/notAfter)
- Verificare che il certificato non sia stato revocato (CRL/OCSP)
- Verificare la catena di certificati fino a un trusted root CA
- Verificate la firma decrittandola con la chiave pubblica presente nel certificato e confrontando il risultato con il digest del messaggio (sempre calcolato con l'algoritmo specificato nel certificato

83. Indicare gli errori di questa frase: ho un server che cifra i dati con certificato X.509 a 2048 bit, protetto con un reverse proxy che verifica le password con un algoritmo RIPEMD.

Il certificato x.509 non è un algoritmo di cifratura ma uno standard per le certificazione dell'autenticità di un utente/host. Mentre RIPEMED è una funzione di hash che può essere utilizzata per verificare una password. Il reverse proxy non protegge ma fa solo forwarding.

3 errori.

84. Descrivere il salvataggio di password lato server. Rischi e contromisure.

85. A vuole mandare a B un file F di 100 MB, avendo le proprietà di sicurezza di riservatezza, autenticazione e integrità. A ha il certificato X.509 di B (la chiave pubblica). Non usare strutture dati complesse e descrivere i passaggi con i nomi dei protocolli piuttosto che con il generico.

k=DH

C=AES128_CBC(F,k,IV)

K=RSA(k, Kpub) (Kpub from certifiate)

D=HMAC_SHA256(Kpub, C || K || IV)

send A and B, M=C || K || IV || D

86. Se vogliamo inviare un messaggio PKCS#7 envelopedData a una persona, e a tre persone, cambierà la taglia del messaggio?

Si, dato che la envelopedData contiene un campo info per ogni ricevente

Capitolo 5- Sicurezza delle reti IP

87. Descrivere almeno due tipi di attacchi possibili con ICMP e le contromisure da adottare per evitare tali attacchi.

ICMP è utile prevalentemente per l'operazione di PING, che permette di mandare un ICMP echo request per sapere se la macchina destinazione se è in ascolto o meno, grazie alla ricezione di un ICMP echo reply, garantendo informazioni utili per la gestione della rete. Se un attaccante ne prende il controllo può causare gravi danni. Due possibili attacchi a ICMP sono:

- **Smurfing attack**. Un attaccante cambia il proprio indirizzo IP con quello della macchina vittima (mediante IPSpoofing). Dall'esterno della rete mando un ICMP echo request con destinazione broadcast in una sottorete, inserendo l'IP della macchina vittima. In questo modo, la vittima riceverà ICMP echo reply da tutte le macchine della sua rete, provocando un attacco DoS saturando la scheda di rete dalla vittima. Una possibile contromisura da adottare se l'attaccante è esterno alla rete è impedire al traffico broadcast di arrivare da una sorgente esterna; se l'attaccante è interno si adottano meccanismi di IDS.
- **ICMP redirect**. Redirect è un messaggio che il DG manda al client per indicargli una strada migliore, magari più veloce, da prendere per raggiungere una certa destinazione. Questa viene memorizzata nella cache del client. Un attaccante potrebbe intercettare un pacchetto diretto verso un altro host e rispondere preventivamente con un ICMP redirect verso sé stesso, in modo tale da poter fare sniffing del traffico. Contromisura: ignorare ICMP Redirect.

88. Spiegare l'ICMP redirect attack.

Il comando Redirect di ICMP avvisa un host che esiste una rotta più breve per la destinazione richiesta, che passa attraverso un altro gateway indicato nel messaggio Redirect. Un attaccante può forgiare un ICMP Redirect mediante un IPSpoofing del default gateway, inserendo come Redirect la macchina host dell'attaccante in modo tale che sia in grado di sniffare il traffico generato dall'host (che memorizzerà nella sua cache la macchina attaccante per arrivare a tale destinazione). Per evitare questo attacco, che fa parte della categoria MITM, posso disabilitare i REDIRECT con un conseguente calo di prestazioni della rete, in una rete con un solo DG è possibile ignorare i messaggi ICMP redirect senza aver un calo di prestazioni.

89. Descrivere l'architettura basic VPN: che cos'è, l'implementazione, vantaggi e svantaggi.

Cos'è, in breve. L'architettura basic VPN consiste nel fare in modo che due aziende che si trovano in aree geografiche diverse possano comunicare in maniera trasparente come se appartenessero alla stessa rete fisica. E' un approccio utilizzato in un contesto di fiducia all'interno delle aziende ma sfiducia nella zona internet attraversata nella comunicazione tra i due Gateway.

Implementazione: IPsec viene installato sui Gateway. Quando un Host A appartenente alla rete di Milano vuole mandare un pacchetto a un Host B appartenente alla rete di Torino, il pacchetto viene mandato al Gateway G1, che lo imbusta in un pacchetto IP con destinazione Gateway dell'azienda di Torino G2. Quindi da pacchetto A con destinazione B, diventa un pacchetto G1 -> G2 che imbusta il pacchetto A-> B (tunnel mode). Il pacchetto quando arriva a G1 viene protetto da IPSec utilizzando ESP. Si ricordi che ESP viene utilizzato per garantire Autenticazione, Integrità ed eventualmente Confidenzialità del solo payload; tuttavia in questo contesto, dato che inserisco un header IPv4 aggiuntivo per via del tunnel mode, il pacchetto interno originale può essere visto come "payload", di conseguenza sarà protetto nella sua interezza, fornendo autenticazione e integrità di tutto il pacchetto con header compreso. Una volta arrivato a destinazione, il Gw destinazione verifica che autenticazione e integrità siano soddisfatte, ed eventualmente decifra il pacchetto se in ESP è stata attivata la modalità Confidanzialità, e invia il pacchetto in chiaro all'host B.

+ i gateway sono provvisti di acceleratori Hardware dedicati, di conseguenza il lavoro di encrypt, e il calcolo di hash è velocizzato.

+ Le due sedi riescono a comunicare tra loro in maniera trasparente come se appartenessero alla stessa rete fisica
+ protezione da attacchi MITM e sniffing nel trasporto del pacchetto tra gateway

- vulnerabile ad attacchi di sniffing e MITM nella rete interna dato che il pacchetto arriva in chiaro.

IPv4Tunnel | IPSec | IPv4 | datagram |

90. Disegnare e discutere della End-to-end security with basic VPN

L'architettura end-to-end security è utilizzata in un contesto in cui un'azienda ha le sue sedi poste in aree geograficamente diverse, e si vuole fare in modo che la comunicazione tra due host appartenenti a due sedi diverse sia trasparente, come se appartenessero alla stessa rete fisica. Ha la seguente implementazione:

- Host A della sede di Torino vuole comunicare con Host B della sede di Milano. A genera un pacchetto IPv4 proteggendolo con IPSec in transport mode, con AH o ESP. (ricordiamo che IPSec transport mode è usato per la sicurezza end-to-end, in questo caso tra host e gateway, quando non ci si fida della LAN, e consiste nel lasciare l'IP originale in chiaro e inserire l'IPSec tra IPv4 originale e il payload).
- Il gateway riceve il pacchetto generato da A e lo imbusta in un pacchetto con destinazione Gateway della rete destinazione. Il pacchetto imbustato viene protetto con ESP in tunnel mode, che tratta il pacchetto ricevuto come se fosse un payload, ed è in grado di garantire A+I e C sull'intero pacchetto e non solo sul payload.
- Il gateway destinazione riceve il pacchetto, ed estrae il pacchetto originale cifrato, e lo invia all'host destinazione.
- L'host destinazione decifra il pacchetto estraendo il pacchetto originale in chiaro.

Quest'architettura è da inserire in un contesto in cui non c'è fiducia né nella WAN né nella LAN: il traffico trasmesso all'interno della rete è pertanto immune allo sniffing e ad attacchi MITM. Purtroppo però è necessaria una doppia azione di cifratura, IPSec è installato sia nei gatway sia negli host, rendendo la procedura estremamente più lenta e trasferendo pacchetti molto più grandi di quelli originali per via del vasto numero di dati aggiunti.

91. Un'azienda decide di collegare due sue filiali con una vpn del fipo basic VPN: dire caratteristiche, vantaggi e rischi

La basic VPN si applica in contesti in cui ci si fida della LAN ma non ci si fida della WAN. In particolare, si imbustano pacchetti IP che arrivano al gatewat in altri pacchetti IP con modalità tunnel mode, proteggendo il pacchetto IP originale utilizzando ESP in tunnel mode (che garantisce A + I sull'intero pacchetto). I gateway sono dotati di acceleratori hardware che permettono di velocizzare le operazioni crittografiche.

92. Cos'è RADIUS, quali sono le caratteristiche di sicurezza e quale ruolo ha in una architettura di sicurezza.

Radius è un protocollo di autenticazione via rete. Fornisce la struttura necessaria per far comunicare NAS e AS, mediante il protocollo RADIUS. Un pacchetto RADIUS è formato dalle seguenti parti: Codice identificativo (Requested, Accept, Reject, Challenge), id (univoco per ogni pacchetto), lunghezza del pacchetto, autenticatore (contenente i dati per fare autenticazione, ad esempio un Nonce) e attributi (contiene i dati dell'utente che arrivano al NAS sottoforma di collegamenti punto punto con PAP, CHAP o EAP, trasformati nel formato Type-Length-Value).

Garantisce le seguenti proprietà di sicurezza

- Non permette attacchi replay grazie all'identificativo univoco contenuto in ogni pacchetto

- Permette di evitare attacchi di concatenazione di altri dati, grazie all'indicazione della lunghezza del pacchetto

- Protezione dei dati in transito tra NAS e AS, fornendo Integrità e autenticazione reciproca tra le due entità in comunicazione. Questo avviene perché le password che l'utente invia al NAS vengono crittografate nel seguente modo: concateno l'autenticatore contenuto nel pacchetto RADIUS citato precedentemente con un segreto, una chiave simmetrica che conoscono entrambe le parti, e ne calcolo l'hash con algoritmo MD5: MD5(key || autenticatore). I dati in uscita vengono posti in XOR con la password dell'utente a cui viene aggiunto un padding di 0 fino ad arrivare a 128 bit di MD5. In questo modo si garantisce integrità e autenticazione per via del possesso reciproco di una chiave simmetrica.

- La risposta di AS verso NAS deve essere ugualmente protetta, quindi si prende l'autenticatore precedente ricevuto dal NAS (MD5 (key || autenticatore) XOR password) e lo si concatena con la risposta del pacchetto nuovo generato. Se ne fa keyed-digest usando la stessa chiave condivisa, e questo sarà un nuovo autenticatore.

RADIUS fa tendenzialmente da proxy verso altri server di autenticazione: un utente che si presenta al proprio server con un dominio adeguato (@realm dei dispositivi NAS), il server stesso gestisce l'autenticazione attraverso un DB locale; altrimenti se si usa un dominio differente, il server radius riceverà le informazioni dal server del dominio indicato.

93. Quali sono i problemi di sicurezza del protocollo ICMP?

L'utilizzo di ICMP è vitale per la corretta gestione della rete perché ci da informazioni se la macchina destinazione è in ascolto o meno. Essendo priva di protezione perché è un protocollo di livello IP, i problemi di sicurezza possono essere:

- **ICMP Destination Unreachable** sono messaggi che vengono solitamente utilizzati da un nodo intermedio tra A e B per comunicare l'impossibilità di consegnare un pacchetto al destinatario. Se un attaccante forgia questi pacchetti impersonificando un nodo intermedio, il traffico verso il nodo destinatario viene bloccato causando DoS in quanto il mittente interrompe la trasmissione dei pacchetti. Questi messaggi possono avere una durata maggiore rispetto alla singola connessione perché gli stack di rete memorizzano le risposte ricevute.

- **Time exceeded for a datagram**: è un messaggio ICMP che interrompe la connessione tra due nodi quando un client ci mette troppo tempo per connettersi a un server. Un attaccante lo sfrutta per generare un loop nella rete in modo da far scattare un timeout per la comunicazione client e server, per generare DoS e far cadere la connessione tra due nodi.

- **ICMP Source Quence**. E' utilizzato per rallentare la connessione nella direzione server-client qualora ci fosse differenza di velocità tra le due entità. Un attaccante può forgiare questi messaggi mediante IPSpoofing del nodo vittima, arrivando a far trasmettere al server dati a una banda molto piccola.

- **ICMP redirect**. È un messaggio che manda un default gateway a un nodo sorgente indicandogli un altro Default Gateway che arriva alla destinazione con un minor numero di HOP. Un attaccante può forgiare questa tipologia di pacchetti generando una destinazione che comprende l'attraversamento del proprio nodo, in modo tale da poter fare sniffing dei pacchetti in transito.

- **Smurfing attack**. Un attaccante esterno alla rete fa IPspoofing con ip della vittima, e manda un ICMP echo request a destinazione broadcast. In questo modo, la macchina vittima riceverà ICMP echo reply da tutti i nodi della rete, causando DoS.

94. Cos'è un ARP spoofing attack?

Il protocollo ARP serve per fare una traduzione da indirizzi destinazione di livello 3 a indirizzi destinazione di livello 2 (MAC), questa associazione è salvata in una cache di ARP in ogni host. Una ARP request viene fatta in broadcast a tutti gli host della rete fisica, solo quello interessato risponde. Le ARP request avvengono in un

contesto friendly, tant'è che è stata introdotta anche la Unsolicited Arp Request, che permette ad altri host di memorizzare nella propria cache le Arp Reply non destinate a loro. questa è però un'arma a doppio taglio: un attaccante può inviare delle Arp Reply fasulle al posto della macchina host interessata, facendo in modo di sporcare non solo la cache della macchina che ha mandato una Arp Request, ma sporcando tutte le altre macchine grazie alla Unsolicited Arp Request. In questo modo è possibile inviare traffico direttamente all'host dell'attaccante per poter effettuare attacchi MITM.

95. Dire che cos'è dns cache poisoning.

Il protocollo DNS serve per fare **traduzione da un nome a un indirizzo IP**. Tipicamente quando si fa una ricerca su internet si scrive il nome del sito, il browser verifica nella propria cache per vedere se possiede la traduzione IP del nome del sito. In caso negativo, contatta un NameServer locale che mantiene la cache dell'intera rete. Se nanche il nameserver possiede la traduzione, si naviga la Root NameServer che provvederà a contattare i nameserver al di sotto di lui per fornire la traduzione giusta. Questo avviene in un contesto non protetto: non c'è autenticazione tra nameserver o verifica della risposta, viene presa per buona la prima che arriva. Per questo motivo è facilmente attaccabile. L'attacco di cache poisoning cha 2 versioni:

- **V1**. Poiché la maggior parte delle traduzioni ip logico – nome sono già presenti nella cache del nameserver locale, si sfrutta il fatto che quando si fa una query per un sito non memorizzato in cache, un attaccante si immette nella comunicazione tra client e nameserver, fornendo per primo una traduzione fasulla sia per il sito richiesto sia per altri siti già memorizzati in cache, in modo tale da sostituire la cache del nameserver sporcandola con associazioni fasulle, che portano l'utente a entrare su siti con la stessa interfaccia dei siti normali (ad es www.paypal.com) ma che in realtà non sono quelli originali.
- **V2.** La seconda versione accelera i tempi di compromissione del server: un attaccante fa una query a un nameserver e invia immediatamente dopo la risposta alla query appena effettuata mandando un'associazione fasulla, sporcando di fatto la cache del nameserver a cui si è fatto la query sostituendo l'associazione precedente vera con quella finta.

96. DNS flash crowd: Spiegazione e contromisure

Un attacco DNS flash crowd sono attacchi DNS contro i nameserver. Molti nodi si collegano nello stesso tempo a un server per metterlo fuori uso. Questo attacco provoca un sovraccarico di richieste a un DNS server. Questo tipo di attacco è illegale se si utilizzano dei bot. Essendo un attacco DoS, eventuali contromisure potrebbero essere: monitoraggio o sovradimensionamento del sistema.

97. Ping flooding, cos'è e come difendersi in modo da non alterare il normale traffico tcp/ip

Ping flooding è un attacco DoS in cui si inviano in modo massivo tanti messaggi ICMP echo request senza attendere risposta. Non esistono contromisure essendo un attacco DoS, ma solo metodi palliativi basati su approccio quantitativo per mitigare gli effetti:

- Monitoraggio (rilevo anomalie)
- Sovradimensionamento: il sistema è progettato per ospitare più traffico rispetto a quello presente mediamente in una rete in modo tale che l'attacco DoS sia leggermente più difficile da commettere.

98. Descrivere lo sniffing e almeno due modi di effettuarlo.

Lo sniffing comporta il rilevamento di pacchetti trasmessi in rete destinati a un nodo diverso dal nodo dell'eventuale attaccante, al fine di rilevare informazioni sensibili contenute al loro interno. Per contrastarlo è necessario cifrare i pacchetti. Può avvenire sia in maniera logica analizzando il traffico della rete a cui si ha accesso, sia in maniera fisica connettendosi a una porta dello switch. Un modo per poter fare sniffing del traffico è tramite ICMP Redirect, dicendo a un host di far passare il traffico attraverso la mia macchina, o attraverso ARP poisoning creando un'associazione IP – MAC della rete fasulla, facendo sì che il traffico generato per un altro host passi per l'host attaccante.

99. Descrivere l'architettura VPN end-to-end: che cos'è, l'implementazione, vantaggi e svantaggi.

Una VPN end-to-end, è un tipo di VPN utilizzata al fine di proteggere la comunicazione tra due nodi. Viene usato IPSec per proteggere il traffico direttamente tra client e server.

Implementazione: Host A vuole mandare un messaggio a Host B, senza che un terzo elemento appartenente alla lan di B possa sniffare il traffico. utilizzo IPsec in transport mode con AH o ESP se voglio garantire anche confidenzialità. Ricordiamo che IPSec in transport mode applica l'header IPSec tra l'header IPv4 originale e il payload: l'header IPv4 originale è lasciato in chiaro.

I due nodi hanno IPSec implementato direttamente nelle loro macchine e creano un canale virtuale end-to-end sicuro grazie a delle SA che i due host hanno negoziato in una fase precedente (mediante protocollo IKE).

+ i due nodi sono protetti dal resto della rete sia locale sia geografica.

- è necessario installare IPSec in tutti i nodi della rete che si deve proteggere. Questo presuppone che i nodi abbiano capacità crittografiche necessarie.
- l'IP sorg e IP dest sono mandati in chiaro.

100. Che cos'è una S-VPN? Perchè ha questo nome?

Una VPN è una tecnica per realizzare una rete privata usando canali di trasmissione condivisi non fidati, usate dalle aziende con sedi sparse geograficamente per avere un'unica rete logica fittizia. Per far comunicare zone geograficamente opposte è necessario affidarsi ad altri ISP. Sono stati utilizzati tre metodi per realizzare VPN:

- VPN mediante rete nascosta(si faceva router advertising di indirizzi privati) col difetto che il gestore di rete poteva leggere tutto il traffico in chiaro
- VPN mediante tunnel. i router incapsulavano pacchetti IP in altri pacchetti IP mediante logica MPLS. Non ha sicurezza perché chiunque può accedere al router pr leggere le informazione che vuole
- VPN mediante tunnel IP sicuro, Secure VPN: viene aggiunta una proprietà di sicurezza a VPN tunnel mode, facendo sì che quando il traffico esce dalla rete, venga protetto mediante tecniche di cifratura (per garantire riservatezza) e HMAC (per garantire autenticazione e integrità) e numerazione dei pacchetti (per replay). Queste proprietà sono state aggiunte al singolo datagram in modo tale da soddisfare le proprietà di sicurezza. la protezione va fatta direttamente dal client delle VPN e non dal gestore. In questo contesto l'unico modo per impedire la comunicazione è mediante attacchi DoS. L'implementazione di VPN secure avviene mediante IPsec mediante aggiunta di header aggiuntivi al pacchetto, che possono essere di tipo AH o ESP

101. Una azienda deve collegare due sue filiali con una VPN, quale infrastruttura si usa? Come è fatta? Disegnare lo schema, spiegare come viene configurata, vantaggi e svantaggi di questa soluzione.

Un'azienda che deve collegare due sue filiali usa una Secure VPN mediante tunnel IP, con tipologia Basic VPN. In questo contesto viene installato IPsec sui gateway e non sui nodi perché si presuppone che le reti locali siano fidate, mentre le WAN siano non fidate. In questo modo quando due host appartenenti a due aree geografiche diverse vogliono parlarsi, l'host invierà il proprio traffico al suo gateway che provvederà ad aggiungere IPSec in tunnel mode, inserendo un IPV4 aggiuntivo per la comunicazione tra i due gateway. Si garantiscono autenticazione + integrità e confidenzialità grazie ad ESP dell'intero pacchetto che viene considerato come payload.

+ IPSec è installato solo su Gw, che hanno acceleratori Hw dedicati e quindi è un'operazione veloce.
+ è possibile monitorare la parte di rete fidata

- non è garantita protezione end-to-end: se ho un attaccante interno alla rete può effettuare sniffing dei pacchetti perché sono trasmessi in chiaro.

102. EAP: a cosa serve, differenze rispetto a PAP e CHAP.

EAP è un protocollo di autenticazione basato su collegamenti punto punto a livello data-link, per garantire l'autenticazione degli accessi in rete.

- Il protocollo **PAP** viene inviata dall'utente Username e password in chiaro, con risposta sì/no
- Il protocollo **CHAP** è un meccanismo di autenticazione con CRA simmetrica grazie ad algoritmi di digest.
- **EAP** invece si inserisce in un livello intermedio tra lo scambio di dati di livello 2 a livello 3, e fornisce tre opzioni di autenticazione: OTP, token based e MD5-challenge. È un protocollo che assicura una flessibilità dei meccanismi di autenticazione utilizzati, imbustando tutto in un pacchetto EAP per poter essere trasmesso poi sottoforma di collegamenti point to point. Utilizza un proprio protocollo di incapsulamento, indipendente dai dati che gli arrivano dal layer 3, e vuole avere un ack esplicito (sicuro ma poco efficiente). EAP quindi non è un protocollo che di per sé aggiunge protezione ai pacchetti, ma garantisce che i meccanismi di autenticazione forniti da un layer 3 possano essere rese flessibili e imbustate in pacchetti EAP che le rendono poi disponibili a livello 2, senza usare infrastrutture diverse a seconda del meccanismo di autenticazione utilizzato.

103. Radius e quando si usa nelle reti wireless. Problemi di sicurezza in una piccola rete aziendale: che tecnologie adottare?

Possibile usare rete aperta (sconsigliato), rete aperta + autenticazione MAC, rete aperta + gateway web. Meglio rete aperta + gateway web, che intercetta tutto il traffico e presenta una pagina web all'utente chiedendo username + password (Nocat è una soluzione open source). RADIUS si usa nella configurazione rete aperta + gateway e in 802.1x, per controllare le credenziali degli utenti. Problemi: limitare l'accesso alle sole entità autorizzate. Autenticazione dei pacchetti per prevenire hijacking. Si usano chiavi di sessione.

104. Cos'è IPsec e quali servizi di sicurezza offre.

IPSec è un'architettura per fare sicurezza a livello 3 sia per IPv4 sia per IPv6. Permette di creare delle VPN sicure su reti non fidate e fare sicurezza end-to-end tra due nodi di una rete IP. Si implementa aggiungendo un header IPSec nel pacchetto IP originale. In particolare, gli header sono di tipo AH o ESP, che garantiscono due diversi tipi di sicurezza.

AH garantisce:

- Autenticazione + integrità mediante keyed digest del pacchetto IP (composto da header + payload)

ESP invece offre

- Autenticazione + integrità mediante keyed digest del solo payload del pacchetto IP
- Riservatezza del payload del pacchetto IP.

Le proprietà di autenticazione sono garantite grazie allo scambio di chiavi crittografiche simmetriche tra nodo mittente e nodo destinatario. IPSec si suddivide in:

- **IPSec in transport mode**. Utilizzato per garantire sicurezza end-to-end tra nodi, evitando lo sniffing nella propria rete interna. Si inserisce l'header IPsec tra l'IPv4 e il payload
- **IPSec in tunnel mode**. Utilizzato per la creazione di Secure VPN. Viene aggiunto un header IPv4 per la comunicazione tra gateway, successivamente si mette l'header IPSec che garantisce le proprietà di sicurezza elencate sopra su tutto il pacchetto successivo (anche applicando ESP perché il pacchetto IP originale viene trattato come se fosse un payload).

IPsec protegge inoltre da attacchi di tipo replay grazie al sequence number contenuto negli header AH e ESP.

105. IPsec in transport mode con ESP: quali misure di sicurezza sono permesse (indicare quelle obbligatorie e quelle facoltative) e come vengono realizzate?

IPSec in transport mode garantisce la sicurezza end-to-end. Si inserisce l'header di IPSec tra l'header IPv4 e il payload. Le misure di sicurezza obbligatorie sono: Integrità e autenticazione dell'intero pacchetto, ossia implementazione di AH, dato che l'IPv4 originale viene trasmesso in chiaro voglio che sia possibile garantire che non venga modificato. Se la comunicazione necessita riservatezza è possibile applicare anche confidenzialità del payload con ESP, cifrando di fatto i dati.

I+A sono garantite grazie a una chiave simmetrica comune tra i due nodi, mediante un keyed digest. La chiave va scambiata mediante il protocollo IKE, per memorizzarla nella propria SAD con IPsrc IPdst ProtType.

Garantisce protezione parziale da replay grazie al sequence number.

106. Spiegare attacco smurfing.

Un attacco ICMP smurfing consiste nel mandare un pacchetto ICMP echo request inserendo come IPsorgente quello della vittima (mediante IPSpoofing) e IP destinazione un indirizzo broadcast nella rete. Il pacchetto viene mandato in una sottorete (chiamata in questo contesto reflector), causando l'invio di tantissimi messaggi ICMP echo reply saturando la scheda di rete della vittima. Una potenziale contromisura consiste nel non accettare pacchetti broadcast provenienti dall'esterno, qualora l'attaccante fosse esterno. se invece si tratta di un attaccante interno alla rete, si utilizzano meccanismi di IDS.

107. Spiegare che cos'è 802.1x, identificare chiaramente quali sono i suoi

IEEE 802.1x è un'architettura di **autenticazione** e **key-management** a livello 2 per fornire autenticazione a dei supplicant che vogliono accedere a un servizio di rete, ad esempio a nuovi nodi che si aggiungono nella rete, sia ethernet sia wifi. In particolare, una volta riconosciuto l'utente (quindi fatta autenticazione) si avvia la procedura per la generazione di chiavi di sessione simmetriche per poter cifrare la comunicazione, per evitare sniffing su reti wifi.

Un **autenticatore NAS** ha la lista degli utenti che si possono collegare al dispositivo (oppure si appoggia a un server radius esterno).

- Quando un client si connette all'access point wifi comunica mediante un protocollo **EAP over wireless**
- Quando un client si connette a uno switch usa **EAP OVER LAN**
- Se Access point o switch non hanno il nome dell'utente nel proprio db, incapsulano i dati in un pacchetto **EAP over RADIUS** chiedendo autenticazione a un server esterno AS.

La procedura avviene nel seguente modo:

- Supplicant vuole avere accesso alla rete e invia un pacchetto EAPOL se si collega alla LAN al NAS
- Nas di default blocca l'accesso alla rete, e manda al supplicant un EAP request identity.
- Supplicant risponde con un EAP respond identity
- NAS traduce EAP response identity in un pacchetto Radius Access Request, e lo manda al server AS radius
- Radius manda Radius Access Challenge
- NAS traduce Radius Acces Challenge in EAP request
- Supplicant manda EAP Response con le credenziali
- NAS manda Radius Access Request
- AS risponde OK -> NAS risponde OK.
- L'accesso alla rete è garantito.

Il NAS blocca l'accesso alla rete finchè il supplicant (ovvero l'entità che si vuole collegare) non verrà riconosciuto. Il NAS incapsula i dati ricevuti da EAP response identity in pacchetti radius access request verso il server radius (AS). fa da proxy nella comunicazione tra supplicant e AS, traducendo i pacchetti dal formato eapol a formato eap over radius.

108. ESP: descrivere la procedura, le trasformazioni, come sono ottenute le informazioni richieste.

ESP è un tipo di header IPSec che garantisce confidenzialità del payload e A+I del solo payload. Garantisce anche le protezioni contro attacchi di tipo replay.

Nel caso di un header ESP con algoritmo a blocchi CBC le informazioni contenute sono le seguenti:

- Initialization Vector da 64 bit
- Payload + padding cifrato con la K simmetrica per cifratura
- Sequence number per garantire protezione contro attacchi reply
- Dati di autenticazione, Integrity Check Value. Digest del payload + padding + Ksymm2.

Per fare ESP è necessario attivare una procedura chiamata IPsec key management qualora non ci fossero le chiavi simmetriche nel Security Association Database. Per lo scambio di chiavi viene quindi utilizzato il meccanismo IKE, che si suddivide in due fasi:

IKE phase 1 – negoziazione di una **Security Association ISAKAMP** bidirezionale in main mode o aggressive mode(autenticazione mediante firma digitale, CRA simmetrica o asimmetrica / key agreement per la generazione di una SA ISAKAMP) per cifrare la comunicazione successiva. Questa SA ha una durata lunga.

IKE phase 2 – scambio di una **SA IPsec** in quick mode o new group mode, vengon scambiati chiavi e algoritmi per cifrare i messaggi successivi con IPSec finchè la SA ISAKAMP dura. Queste informazioni vengono inserite nel SAD. Queste SA hanno durata breve a causa dell'elevato traffico generato.

109. Descrivere syn cookie e contro quale attacco è.

Syn cookie è un modo per evitare di far avvenire attacchi di tipo SYN flooding, facendo in modo che il server non abbia bisogno di mantenere una tabella. Serve appunto per mantenere informazioni di stato sul client che vuole collegarsi ad un server. Il procedimento è il seguente:

- Client C manda SYN verso Server S.
- S manda a C un Syn Ack + un Sequence Number, calcolato mediante H(timeout, dimensione segmenti, IP client). In questo modo posso mantenere le informazioni di stato sull'utente.
- C risponde a S con Ack + (SN + 1).
- S verifica se (SN + 1) == H(timeout || dimensione segmenti || ip client) + 1. In caso affermativo, l'utente ha accesso al server.

In questo modo il server riconosce chi aveva mandato il syn in precedenza, senza doverne tener traccia su una tabella. tuttavia l'effetto negativo è rappresentato dal fatto che il server deve effettuare due volte il calcolo degli hash, portando a saturare risorse dal punto di vista computazionale rendendolo vulnerabile a un altro tipo di DoS.

Capitolo 6

Firewall e IDS/IPS

110. Un'azienda desidera rendere disponibile ai navigatori internet, un servizio http sulla porta 8080, indicare una configurazione della rete e/o del server per erogare il servizio in modo sicuro e spiegare il perché delle scelte adottate.

Uso un firewall del tipo screened subnet con il giusto proxy web e web server sulla DMZ così da avere un buon livello di sicurezza dato da gateway, bastion e router con packet filtering, ma allo stesso tempo evitare SPOF dato il doppio controllo fatto sui paccheti

111. Con riferimento ad un firewall di rete, spiegare brevemente le modalità di configurazione whitelist e blacklist

Un firewall di rete è l'equivalente di un muro tagliafuoco, un dispositivo che si trova a metà tra rete esterna e rete interna al fine di proteggere il traffico diretto verso la rete interna o di permettere alla rete interna di mandare verso la rete esterna solo un tipo di traffico prestabilito. In particolare, ci sono due politiche di autorizzazione:

- **Whitelist**. Viene identificata una lista contenente soltanto ciò che è permesso. Tutto quello che non è presente su questa lista, è bloccato. Ha una sicurezza maggiore, ma per contro è molto difficile da gestire e definire il traffico permesso soprattutto in un'azienda di grosse dimensioni.
- **Blacklist**. Complementare al prcedente: viene identificata una lista contenente tutto ciò che non è permesso. Quello che non è presente sulla lista, è concesso. La lista può essere aggiornata in seguito a determinati attacchi subiti (ad esempio se ci si accorge che un determinato tipo di traffico proveniente da determinati pacchetti http è malevolo, blocco quei pacchetti). Il problema è che è un sistema meno sicuro perché agisce a posteriori. È più facile da gestire.

112. Descrivere l'architettura firewall screened host gateway indicando attori, vantaggi e svantaggi.

In un'architettura di tipo firewall screened host gateway gli attori coinvolti sono:

- **Router** con funzionalità di **packet filter** (**screening router**, fa da ponte tra rete interna e rete esterna). Ha al proprio interno delle regole al proprio che permettono di filtrare traffico a livello 3 in base alle 5-tuple ipsrc ipdst psrc pdst protocoltype.
- **Gateway**. Una macchina a cui è stato attribuito il ruolo di **bastian host**, ovvero, vengono tolti tutti i servizi non necessari e vengono installate tutte le patch di sicurezza (procedure di auditing). Ha Application Gateway per controllare i servizi autorizzati (esamina i pacchetti a livello applicativo per uno specifico protocollo, può fare autenticazione e autorizzazione). Permette quindi il mascheramento della rete interna.

Un pacchetto che proviene dall'esterno verso l'interno deve essere prima di tutto autorizzato dal packet filter. In caso positivo, il pacchetto può prendere 2 direzioni:

- Se la direzione del pacchetto dalla **rete esterna verso la rete interna** è verso un Server Web o un Server Mail, il packet filter lo inoltra direttamente a destinazione, quindi direttamente nella rete interna (Accesso a canale privilegiato)
- Se la direzione del pacchetto è verso un host della rete interna, il pacchetto viene trasferito al gateway per poterne effettuare un'ulteriore indagine.

Il controllo avviene anche in senso opposto: un utente della rete interna per poter accedere a determinate URL o a servizi particolari deve per forza passare dal gateway.

Quindi in sostanza lo screened router accetta traffico solo se diretto al Bastion Host o a servizi abilitati direttamente; e inoltra traffico soltanto se proveniente dal bastion.

+ Flessibile, alleggerisco i controlli effettuati dal gateway

- mascheramento: posso mascherare solo i pacchetti che passano dal gateway.

- Alcuni host della rete interna sono direttamente raggiungibili dall'esterno, e sono quindi più attaccabili (causa della non perfezione di un packet filter, non fanno autenticazione, vulnerabile a IPSpoofing, non gestisce frammentazione)

- Sistema poco economico: necessità sia di GW sia di Router.

113. Descrivere la tecnologia del packet filter e descrivere vantaggi e limitazioni.

I packet filter sono dei filtri presenti sui router, estraggono dal pacchetto in entrata e in uscita le informazioni relative alle 5 touple (IPSrc, IPdst, Psrc, Pdst, Protocoltype) e permettono l'accesso o meno di pacchetti sia dall'interno verso l'esterno sia dall'esterno verso l'interno in base a delle regole precedentemente definite. Si suddividono in:

- **Static packet filter**: filtraggio grossolano in base alle 5 touple (una 5 toupla può passare, un'altra no) con un sistema blacklist o whitelist
- **Dynamic (statefull) packet filter**: memorizza le informazioni di stato sia a livello trasporto sia a livello applicativo. È in grado di distinguere connessioni già aperte (ad esempio quelle successive al completamento del protocollo 3-way handshake) permettendo di far passare questi pacchetti, rendendo il sistema molto veloce, grazie a una tabella di stato: non vengono fatti ulteriori controlli per pacchetti la cui connessione è stata accettata.
    - È quindi in grado di far passare connessioni related in quanto preventivamente autorizzate.
    - È in grado di far passare DNS Request e Reply e pacchetti ICMP Ping request e reply.
    - Completa il 3 way handshake: un attaccante non può mandare solo l'ACK finale per far far liberare una riga in più della tabella di stato, ma deve completare tutto il processo.

+ Soluzioni molto scalabili
+ buone prestazioni (il controllo è molto veloce)
+ economici

- Configurazione complessa
- Vulnerabile a IPSpoofing: non garantiscono autenticazione
- non si possono controllare URL
- Non gestisce frammentazione dei pacchetti IP

114. Disegnare lo schema di un'architettura firewall di tipo dual homed gateway, illustrarne il ruolo dei componenti, vantaggi e svantaggi.

In un'architettura dual homed gateway abbiamo come componenti:

- Uno **screening router**, configurato per far arrivare il traffico soltanto al Gateway
- Un **dual-homed gateway**, ovvero un gateway con due interfacce di rete: una verso la rete esterna e una verso la rete interna

In questo sistema ho quindi un doppio controllo: il router funge da packet filter, e fa passare il traffico dall'esterno solo diretto al gateway. Il Gateway invece dispone o:

- di un **Application Gateway**. Analizza il contenuto di un pacchetto a livello applicativo solo per uno specifico protocollo e possono avere funzioni di autenticazione basate su u+p, token crittografici

- O di un **circuit gateway**. Lavora tra L4 trasporto e L5 applicazione, gestisce alcuni processi a livello trasporto come 3 way handshake (a cui successivamente può succedere un protocollo di autenticazione in base alle 5-touple per verificare se il flusso era previsto o meno) o la frammentazione: riassembla pacchetti IP e verifica che i protocolli siano rispettati proteggendo anche da attacchi a L3.

Se un pacchetto proveniente dall'esterno soddisfa sia i controlli effettuati dal packet filter sia i controlli effettuati da application o circuit gateway, può essere inoltrato dalla rete interna (che risulta appunto mascherata dal gateway). Viceversa se dalla rete interna si vuole comunicare verso l'esterno la richiesta passerà solo attraverso il gateway, e se il traffico è autorizzato, provvederà a inoltrare la richiesta alla rete esterna, viceversa interromperà la connessione

+ soluzione più sicura: ho due linee di difesa
+ Semplice, si presta bene ai vendor per essere acquistata
+ la rete interna risulta completamente mascherata

- Necessità di configurare due elementi (packet filter e circuit gateway)
- Soluzione poco flessibile
- Il gw rappresenta un collo di bottiglia perché è sovraccaricato
- il gw è visibile dall'esterno, quindi può essere soggetto ad attacchi.

115. Packet filter e circuit gateway all'interno di un firewall: somiglianze, differenze, vantaggi e svantaggi di entrambi.

Il Packet Filter filtra i pacchetti in base all'intestazione a livello 3. In particolare, esistono due varianti:

- **Packet Filter Stateless**. Fa passare traffico in entrata o in uscita in base a una blacklist o whitelist in cui vengono indicati IPsrc IPdest PortSrc PortDest, ProtocolType. Questo per ogni pacchetto.
- **Packet filter Statefull**. In questo caso il firewall mantiene informazioni di stato a livello trasporto o applicativo, memorizzate in una tabella delle connessioni. Infatti è in grado prima di tutto di completare il 3 way handshake per conto del server (evitando attacchi relativi al packet filter, secondo cui bastava solo l'ack finale: in questo caso un client deve completare tutte le fasi), successivamente memorizza la connessione sulla propria tabella: quando arriverà traffico relativo a quella connessione aperta, è in grado di farlo passare senza che venga effettuato un controllo, perché è traffico relativo alla tabella delle connessioni. Quindi è in grado di far passare traffico relativo a una connessione precedentemente aperta: distingue il traffico proveniente da una connessione già aperta rispetto a quello proveniente da una connessione non ancora aperta. Questo meccanismo lo rende molto più veloce dei pacchetti stateless

+ è una soluzione poco costosa e molto scalabile, veloce e performante in quanto i dati da estrarre e i controlli da fare sono veloci.

- Non è in grado di garantire autenticazione del pacchetto (per colpa di IPSpoofing non è possibile fare autenticazione basata su indirizzo IP) e non gestisce la frammentazione dei pacchetti. Configurazione complessa

Il **Circuit Gateway** invece filtra pacchetti in base all'intestazione a livello 4. In particolare, si occupa di creare un circuito di livello 4 (quindi livello trasporto) nella comunicazione tra client e server, senza aver comprensione della sintassi dei dati in transito. Agisce perciò come proxy per il server: si occupa di riassemblare pacchetti IP frammentati per verificare se rispettano le regole di controllo.

+ Protegge da attacchi riguardanti l'handshake
+ Isola da attacchi riguardanti la frammentazione dei pacchetti IP
+ Maschera la rete interna
+ Alcuni prodotti tipo SOCKS possono autenticare il client
+ Può interrompere una connessione se questa non è corretta senza sprecare risorse per mandare al client una risposta

- Se si inserisce autenticazione è necessario modificare l'applicazione

- Non protegge da attacchi a livello applicativo.

Notiamo quindi che il circuit gateway può fare da proxy verso il server, inoltrando le richieste dal client al server attraverso di lui, con la possibilità di mascherare la rete interna a cui appartiene il server. è in grado di proteggere da attacchi relativi alla frammentazione di pacchetti IP a differenza del packet filter, anche se il riassemblaggio di pacchetti (che verifica che il protocollo utilizzato sia corretto) rende il processo un po'più lento. Può anche fornire autenticazione. Nessuno dei due protegge però da attacchi a livello applicativo. Ad esempio il circuit level gw può verificare assemblando su un pacchetto IP che la richiesta http è diretta nella porta 80; e questo sarebbe giusta. Non avendo però comprensione dei dati all'interno, non può sapere se la richiesta in entrata non sia relativa a un tipo di attacco a livello applicativo.

116. Packet filter e application level gateway all'interno di un firewall: somiglianze, differenze, vantaggi e svantaggi di entrambi.

Il **packet filter** filtra i pacchetti in base alla regola delle 5 tuple, ovvero, in base a IPSrc IPdst PortSrc PortDst, ProtocolType grazie a una WhiteList o a una BlackList. La versione stateless fa questo controllo per ogni singolo pacchetto, viceversa la versione statefull è in grado di mantenere traccia delle informazioni di stato a livello trasporto di un pacchetto, e distinguere pacchetti provenienti da connessioni già aperte e pacchetti provenienti da connessioni non ancora aperte grazie a una tabella delle connessioni aperte. I pacchetti in entrata che corrispondono ad una riga della tabella non vengono controllati ulteriormente, rendendola molto più veloce di quella stateless.

- Il packet filter non può fornire meccanismi di autenticazione in quanto le informazioni di autenticazione a livello 3 non sono attendibili (causa attacchi IPSpoofing)
- Non protegge da attacchi sulla frammentazione dei pacchetti IP
- difficile da configurare per via della presenza di servizi, come FTP, che hanno porte allocate dinamicamente.

+ veloce e performante ed economico.

L'application level gateway invece ha la capacità di filtrare i pacchetti a livello 5. In particolare, ha piena comprensione dei dati in transito. Fornisce un meccanismo di comunicazione tra Client e Server agendo come proxy per il server: le richieste inoltrate dal client passano attraverso il gateway e, se passano i controlli di sicurezza, vengono inoltrate al server (e viceversa). Fa quindi dei controlli più sofisticati, sia a livello trasporto sia a livello payload, perché è in grado di interpretarlo. Gli attacchi filtrati sono stati catalogati grazie ad OWASP. È composto al proprio interno da diversi proxy, uno per ogni protocollo a livello applicativo.

+ fornisce meccanismi di autenticazione a livello applicativo basati su U+P o token crittografici
+ maschera la rete interna a cui appartiene il server
+ Massima sicurezza grazie ai controlli a livello applicativo: filtra attacchi di injection o buffer overflow
+ Sistema trasparente per l'utente, grazie alla presenza di un'interfaccia con delle checkbox che permettono all'user di stabilire su cosa fare i controlli (complessità nascosta)

- Presenza di numerosi proxy all'interno, che devono essere aggiornati (e possono verificarsi problemi di ritardo di aggiornamenti)
- l'interpretazione del payload porta un consumo di risorse molto più ampio in quanto richiede molto utilizzo di risorse.
- prestazioni ridotte in quanto si lavora in user mode, quindi c'è tempo aggiuntivo di copia di tutti i buffer da kernel mode a user mode.
- il SO dei gateway è esposto ad attacchi
- non è in grado di interpretare dati cifrati (r encryption prima del gw, con problemi privacy)

117. Disegnare lo schema dello "Screened Subnet". Indicare il ruolo dei singoli componenti. Vantaggi e svantaggi di questo schema.

In un'architettura screened subnet gli attori coinvolti sono:

- **Router esterno R1** (con funzionalità di screening router, grazie al packet filter): fa passare i pacchetti mandati verso Gw o Web server / mail server altri server con canale privilegiato
- **Router interno R2**(con le stesse funzionlità del router esterno): fa passare i pacchetti in entrambe le direzioni Gateway – rete interna; consente la comunicazione tra rete interna e DMZ.
- **Bastian Host Gateway**, che ha funzionalità di Circuit Gateway o Application Gateway.

In questo tipo di architettura, un pacchetto che arriva dall'esterno viene sottoposto a un primo controllo da R1, che permette il traffico soltanto se è diretto verso il Gateway o verso un Web Server.

Notiamo che in questo tipo di architettura il Web Server è posto in una zona di sicurezza intermedia, chiamata DMZ: esso non si trova infatti nella stessa rete interna mascherata dal gateway, di conseguenza un attacco alla rete del Server Web non implica un attacco a tutta la sottorete interna.

I pacchetti diretti verso il Gateway infatti verranno controllati da quest'ultimo e, qualora rispettassero le regole di sicurezza imposte dal firewall, verranno indirizzati nel Router Interno R2, che farà altri controlli relativi al packet filter. Se le condizioni di sicurezza vengono rispettate, i pacchetti verranno inviati nella sottorete interna, garantendone un livello di sicurezza maggiore.

Se un utente della rete interna vorrà comunicare verso l'esterno, dovrà contattare il gateway. È possibile sorpassare questo passaggio inserendo dei collegamenti diretti tra host della rete interna e R1, con una perdita di parte della sicurezza.

+ Livello di sicurezza massiccio: vengono fatti 3 controlli
+ flessibile: posso alleggerire i controlli di alcuni host evitando di passare dal gateway

- costo: è necessario avere 3 apparecchiature
- Differenziazione tra apparecchiature per ridurre il numero di bug comuni

118. Parlare del firewall; dove si può piazzare in una grossa rete aziendale?

in una grossa rete aziendale è opportuno porre i firewall tra la rete interna e la rete esterna. Inoltre, è anche opportuno porre i firewall per poter filtrare il traffico in base al ruolo relativo a una determinata sottorete interna per permettere di soddisfare il principio del least privilege: in questo modo ad esempio la sottorete interna relativa al ruolo Commercio e Finanza non potrà avere accesso alle risorse della sottorete interna IT poiché i pacchetti in entrata e in uscita vengono filtrati e protetti da firewall.

E' inoltre opportuno differenziare le marche dei prodotti comprati (gw, router) in modo tale da coprire un numero maggiore di bug.

È anche consigliato introdurre un honey pot per poter tenere traccia dell'attaccante e per definire più velocemente patch di sicurezza.

119. Cos'è il circuit gateway e da cosa protegge?

Un circuit gateway si occupa di filtrare pacchetti in base all'intestazione di Livello 4, analizzando i dati di livello trasporto senza però avere comprensione del contenuto del payload. SI occupa nello specifico di creare un circuito di comunicazione tra client e server, e fa da proxy verso il server rompendo il modello di comunicazione Client Server: rileva un pacchetto inviato dal client e se questo soddisfa i criteri di sicurezza definiti, inoltra il pacchetto al server. in questo contesto quindi può anche fungere da NAT in quanto maschera la rete interna. Il suo compito consiste nell'assemblaggio di pacchetti IP frammentati e nel controllo relativo alla correttezza del protocollo inviato al server: se ad esempio si sta mandando una richiesta con protocollo http verifica che il numero di porta contenuto sia 80. In caso positivo, spedisce il pacchetto al server.

Può fornire autenticazione a livello trasporto, richiedendo però una modifica da parte dell'applicativo. Una volta completato il 3 way handshake quindi può verificare se il flusso fosse previsto o meno e, in caso negativo, chiudere la connessione senza sprecare risorse per mandare una risposta al lcient.

Protegge quind da attacchi relativi alla frammentazione dei pacchetti; isola da attacchi relativi al 3 way handshake

120. Classificazioni livelli dei firewall e controlli da fare a ogni livello; differenza packet filter e proxy di circuito.

I firewall si classificano in base al livello nello stack ISO OSI in cui lavorano. Man mano che ci si alza di livello, i controlli da fare sono molto più sofisticati ma garantiscono un livello di sicurezza maggiore.

- A **livello 2** può essere implementato un firewall che filtri in base a indirizzi MAC. È tuttavia una tecnica molto utilizzata.
- A **livello 3** posso implementare un Packet Filter, un elemento che filtra i pacchetti in base all'ip sorgente, destinazione e porta sorgente, destinazione e protocol type (5 tuple).
- A **livello 4** posso implementare un Circuit Gateway che verifica la correttezza del protocollo dei dati in transito, estraendo le informazioni di TCP e UDP
- A **livello 5** invece ho un Application Gateway, che è in grado di comprendere la semantica dei dati in transito (legge il payload) a livello applicativo, ed è formato da diversi proxy, ognuno per ogni protocollo a livello 5.

In particolare, il **Packet Filter** è un sistema di filtraggio posto su un router ed è in grado di filtrare i pacchetti solamente in base alle informazioni relative alle 5 tuple. La versione più aggiornata, **statefull**, è in grado di distinguere tra connessioni aperte e chiuse perché mantiene informazioni di stato su una tabella delle connessioni dei pacchetti a livello trasporto o applicativo. Tuttavia è vulnerabile ad attacchi IPSpoofing e non garantisce protezione da attacchi riguardanti la frammentazione di pacchetti IP. Al contrario, il **Circuit Gateway** Proxy è un filtro posizionato su una macchina Gateway Bastian Host, e si frappone nella comunicazione tra client e server facendo operazioni al posto del server, ed è in grado di riassemblare pacchetti IP frammentati verificando la correttezza dei protocolli che vengono mndati al server. Per questo può garantire protezione da attacchi riguardanti la frammentazione di pacchetti IP a differenza del packet filter, e può completare la procedura del 3 way handshake. Può fornire strumenti di **autenticazione** (come SOCKS) per verificare se il flusso era previsto o meno: in caso negativo, interrompe la comunicazione, cosa che il packet filter non è in grado di fornire (l'autenticazione a livello IP non è consigliabile).

121. Architettura dei firewall (con schema), eventuali miglioramenti.

Da una rete esterna a una rete interna tipicamente si mette un firewall, che può essere composto da Screening Router (con packet filter) e gateway (con Circuit Gateway o Application Gateway). Tra firewall e rete esterna solitamente viene posto un NIDS, un primo livello di analisi del traffico di rete.

In un'architettura ideale, quella che offre un livello di sicurezza maggiore (Screened Subnet), è necessario coinvolgere 3 attori: 2 router, uno interno e uno esterno, con funzionalità packet filter, e un gateway. Il router esterno consente la comunicazione diretta verso una zona della rete chiamata DMZ dove si trovano i servizi accessibili direttamente (Web Server, Mail server etc) mentre la comunicazione della rete interna avviene mediante un Gateway verso una zona della rete diversa da DMZ. In questo modo la rete interna è completamente schermata e un attaccante anche se riesce ad accedere direttamente alla rete DMZ faticherà comunque a raggiungere quella interna.

Viceversa dalla rete interna ci si può muovere soltanto verso il gateway, è possibile modificare il comportamento per alcuni host facendo arrivare il traffico direttamente sul router esterno bypassando il gateway, al prezzo di abbassare il livello di sicurezza.

Nella rete interna sono messi degli HIDS sugli host più significativi dal punto di vista di asset e risk analysis, e dei NIDS. I server sono notati di HIDS.

Una soluzione meno costosa della precedente è l'architettura Firewall a 3 gambe, che consiste in un unico gateway che fa il lavoro dei due router + gateway, controllando il traffico tra esterno, DMZ e interno. È

computazionalmente molto oneroso però, ma si presta bene come vendor.

122. Cos'è IDS?

IDS è l'acronimo di Intrusion Detection System. È un sistema che ha lo scopo di identificare l'utilizzo di un computer o di una rete senza autorizzazione: il nostro sistema ha uno stato di "normalità", quando questo stato viene violato il sistema IDS dovrebbe riconoscerlo al fine di riuscire a bloccarlo.

- Un IDS **passivo** identifica delle anomalie che avvengono in un sistema attingendo dalle informazioni presenti su un database, in cui sono indicati dei pattern di comportamento che possono far pensare a un sistema sotto attacco (ad esempio sequenze di operazioni definibili come attacchi forza bruta, o la mancanza di un checksum crittografico in coda a un pacchetto). In sostanza quindi identificano un Attack Signature. Non sono però in grado di rilevare attacchi al di fuori di questo database.
- Un IDS **attivo** al contrario è in grado di rilevare attacchi non presenti su un database. In particolare, grazie all'utilizzo di Machine Learning e Artificial Intelligence sono in grado di apprendere (training) i comportamenti anomali della rete, per poi passare nella fase di monitoring per sapere come analizzare il traffico dei dati. la fase reaction permette di decidere quali decisioni prendere qualora si monitorassero anomalie nel sistema.

Gli IDS possono essere:

- **HIDS**. Pezzi di software inseriti direttamente nei nodi terminali.
    - **SIS** System Integrity Verifier: notifica se alcune porzioni dei file system vengono modificati, ad esempio i registri di windows
    - **LFM** Log File Monitor. Controlla i Log dell'OS
- **NIDS**. Sono delle sonde poste nei nodi di rete, che sniffano il traffico rilevando anomalie nel traffico della rete. Le anomalie rilevanti vengono inviate aun correlatore, che riceve dati provenienti da più NIDS e può avere una visione d'insieme. In questo modo, in base a questi dati, può prendere decisioni su come reagire.

123. Qual è la principale differenza tra un IDS e un IPS?

IDS: intrusion Detection system. È un sistema in grado di rilevare anomalie sia nel traffico della rete (NIDS) sia nella sequenza di operazioni compiute da un host sul nodo terminale (HIDS) per verificare se lo stato di normalità è stato violato e se si stanno compiendo azioni non legittime.

Un **IPS** (Intrusion Prevention System) è invece un sistema di reazione automatizzata al fine di rispondere in seguito alla rilevazione di anomalie. È utilizzato spesso negli IDS in fase di monitoring e rilevamento. Servono in uno scenario in cui se viene rilevata un'anomalia, l'amministratore che ne viene avvertito non è presente fisicamente nel luogo. In questo caso scattano reazioni automatiche, come bloccare la connessione, comunicare col firewall aggiornando le sue regole di filtraggio in base ai dati analizzati (ad es bloccare un certor ange di IP).

124. Illustrare il funzionamento di un componente application-level gateway all'interno di un firewall e discuterne vantaggi e svantaggi.

Un application level gateway fornisce uno strumento di controllo e filtraggio direttamente a livello applicativo. Si posiziona in mezzo alla comunicazione tra client e server, svolgendo delle operazioni per conto del server e per conto del client. è composto da più proxy, uno per ogni protocollo applicativo: c'è un proxy per http, uno per FTP etc.

Quando un client invia traffico al server, questo viene intercettato dall'App Gw, che ne estrae direttamente il payload: è infatti in grado di capire il contenuto del payload del traffico in entrata e, se supera i controlli di sicurezza, vengono inoltrati al server (e viceversa). per questo motivo può anche avere funzioni di autenticazione, soprattutto nella direzione egress firewall, basata su U+P o token crittografici.

+ **Maschera** completamente la rete a cui appartiene il server, può fungere anche da NAT
+ Garantisce un livello di **sicurezza massimo** perché sa interpretare i dati in transito: è quindi in grado di filtrare attacchi di injection o di buffer overflow, o attacchi catalogati nella lista OWASP.
+ **Complessità nascosta**: lato utente, c'è un'interfaccia composta da checkbox su cui l'utente ha la possibilità di abilitare o meno determinati controlli contenuti in OWASP

- **l'eterogeneità** dei livelli applicativi richiede l'utilizzo di diversi proxy, con il rischio di avere ritardi nelle funzioni di supporto offerte dai singoli proxy (aggiornamenti, patch di sicurezza)
- il **gateway è direttamente esposto**, quindi il suo OS è possibile soggetto di attacchi
- **consumo enorme di risorse** computazionali dato che si fanno operazioni estremamente sofisticate
- **Prestazioni basse** dal momento che si lavora in user mode, quindi vanno copiati i buffer da kernel mode a user mode.
- l'autenticazione richiede una **modifica** dell'applicativo.
- non è in grado di comprendere payload **criptati**.

125. Spiegare in cosa consiste la tecnica IPS.

IPS è un intrusion prevention system, un sistema di risposta automatizzato in seguito alla rilevazione di comportamenti anomali nella rete o negli host. È costituito da un IDS che ha il compito di rilevare un'attività sospetta in corso (fase di monitoring) e di un firewall dinamico. Infatti, dopo che l'IDS comunica di aver rilevato attività sospette, l'IPS è in grado di comunicare col firewall aggiornando le regole di sicurezza, filtrando il traffico proveniente da particolari indirizzi IP o bloccando direttamente la connessione.

126. Per un'azienda che ha bisogno di avere un web server, un mail server, di fare access control (non tutti possono accedere a Internet), e di ispezionare il contenuto di tutto il traffico, disegnare un'architettura.

Architettura Dual Homed Gateway: un packet filter fa passare il traffico solo attraverso il Gw che possiede un Application level gateway in grado di controllare tutto il traffico in entrata e in uscita, a livello contenuto. Se supera le regole di sicurezza, può essere lasciato passare.

Capitolo 7- Sicurezza delle applicazioni di rete

127. Proprietà di sicurezza di TLS con algoritmi e chiavi.

TLS è un protocollo di trasporto sicuro a livello sessione. Le proprietà di sicurezza garantite sono:

- **Autenticazione dei peer**. Obbligatoria per i server, opzionale per i client.
    - Il **server (obbligatorio)** si autentica con una sfida asimmetrica implicita da parte del client: invia al client un certificato contenente la chiave pubblica, e il client genererà una response cifrando con la kpub la ksimm da utilizzare.
    - Il **client (facoltativo)** si autentica mediante sfida esplicita, opzionale. In questo caso il browser richiede esplicitamente un certificato, e il client subirà una sfida esplicita.
    - **Algoritmi**: DSA (TLS 1.0), RSA (TLS 1.2), RSA+PSS o ECDSA (TLS 1.3)
- **Riservatezza dei dati (facoltativa)**. Il client genera una Session Key per la cifratura simmetrica dei dati. L'algoritmo utilizzato viene scelto nella fase iniziale di negoziazione. La chiave simmetrica viene mandata dal client al server cifrata con la Kpub del certificato ricevuto (il che riporta all'autenticazione implicita del server.
    - **Algoritmi**: 3DES-CBC (TLS 1.0), AES128-CBC con GCM o CCM (TLS 1.2), AES128, AES256, CCM o GCM, CHACHA20 (TLS 1.3)
    - **Scambio chiavi**: EDH
- **Autenticazione e Integrità dei messaggi + replay (obbligatorio)**. Viene realizzato con Keyed Digest, l'algoritmo di KD utilizzato è negoziato nella fase di configurazione di sicurezza della connessione c-s. per proteggere da filtering il KD viene concatenato con un sequence number, un numero a 64 bit non trasmesso direttamente ma calcolato implicitamente (questo grazie alla sicurezza offerta da TLS in merito a giusto ordine sequenziale, no duplicazioni o segmenti persi). Quindi: **MAC = MD(Key, SeqNumber || Type || Version || Length || fragment)**
    - **Algoritmi:** SHA-1 (TLS 1.0, TLS 1.2), AEAD con generazione KDF con SHA256 o SHA384 (TLS 1.3)

128. TLS, proprietà di sicurezza obbligatorie e facoltative, dire con quali algoritmi e con quali chiavi vengono realizzate

TLS è un protocollo che garantisce sicurezza a livello sessione. Le proprietà di sicurezza offerte sono:

- **Autenticazione dei peer.**
    - **Autenticazione del server** (obbligatoria) mediante sfida implicita (invio di un certificato contenente Kpubblica in seguito alla negoziazione degli algoritmi)
    - **Autenticazione del client** (faclotativa) mediante sfida esplicita (invio di un certificato in seguito a una richiesta esplicita da parte del server
    - Algoritmi utilizzati: DSA (TLS 1.0), RSA (TLS 1.2), RSA+PSS o meglio ECDSA (TLS 1.3)
- **Riservatezza dei dati** (opzionale). Il client genera una Ksimmetrica da mandare al server cifrata con la chiave pubblica (auth implicita del server)
    - Algoritmi cifratura simmetrica: 3DES (TLS 1.0), AES-128 CBC con GCM (TLS 1.2), AES-128, AES-256, CHACHA20 (TLS 1.3)
    - Algoritmi scambio chiave: DH, ECDHE (TLS 1.3)
- **Integirtà + autenticazione + replay (obbligatorio)**. Questi tre principi vengono garantiti mediante il calcolo di un MAC. In particolare, l'algoritmo per il calcolo del MAC viene deciso in fase di negoziazione e

si fa Keyed Digest: HMAC = MD(Key, Sequence Number || Type || Length || Version || Fragment), dove il sequence number è calcolato implicitamente grazie alle proprietà di TCP e garantisce protezione da reply e filtering.

- Algoritmi: SHA-1 (TLS 1.0 / TLS 1.2), utilizzo di AEAD con algoritmi di hash SHA256/SHA384 per generare la Hashed KDF.

129. Quali sono gli step di trasformazione dei dati quando inviati tramite un canale TLS con la ciphersuite TLS_DHE_DSS_WITH_AES_128_CBC_SHA con ZIP

Prima di essere trasmesso tramite TCP un record TLS viene scomposto nel seguente modo:

1- Frammentazione. I record TLS sono lunghi al massimo 2^{14}.
2- Compressione per ridurre la quantità dei dati: PACK.Data = zip(Pack.Data)
3- Calcolo del MAC, in questo caso con Keyed Digest usando SHA256 come algoritmo: HMAC-SHA256(Key_auth_client_to_server, Packet)
4- Padding
5- Generazione IV perché uso CBC, quindi IV
6- Cifratura di dati compressi + MAC + padding con K diversa dalla K utilizzata per fare Keyed Digest. AES-128 CBC = enc(IV + Key_Client_to_server, PACK_DATA)
7- Invio pacchetto cifrato inserendo l'header TLS.

130. Descrivere come funziona la client authentication di TLS. Discutere i suoi vantaggi e i suoi svantaggi.

Nella Client Authentication di TLS è possibile autenticare il client senza necessità di chiedergli Username e Password, ma solo mediante sfida asimmetrica. Viene quindi previsto che un utente possieda un certificato X.509 con cui potersi autenticare. L'autenticazione avviene mediante sfida esplicita del server, dopo essersi autenticato.

1. **Certificate Request** (Server -> Client) richiesta del server in fase di Handshake co elencate le CA accettate
2. **Certificate Challenge Response**. Viene calcolato un Hash di tutti i messaggi precedenti firmati con la Kprivata + il certificato contenente la chiave pubblica, certificato deve appartenere alle CA precedentemente elencate.
3. **Certificate Verify**. Il server verifica se il MAC calcolato da lui coincide con quello inviato dal client decifrato con la sua chiave pubblica. in caso affermativo, il client è autenticato.

+ Il client non ha necessità di ricordarsi Username e password.
+ Il livello di sicurezza è massimo, infatti si limita ai bug della libreria TLS che tuttavia coprono una superficie di attacco estremamente minore rispetto alla superficie di attacco di autenticazione mediante applicazione o canale http.
+ Possibilità di mappare in maniera semi automatica le credenziali estratte dal certificato X.509 con utenti in un livello applicativo.
+ metodo più forte in assoluto per fare autenticazione

- Non è sempre fattibile in quanto richiede il possesso da parte del client di un certificato, cosa non comune.
- difficile istruire l'utente medio nella gestione di chiavi pubbliche e private.

131. TlS client authentication vs HTML form-based authentication: vantaggi, svantaggi e soluzioni

TLS client authentication avviene mediante sfida esplicita in seguito alla richiesta di un certificato da parte del server verso il client, in fase di handshake, in un momento successivo all'autenticazione implicita del server. Il client invia il proprio certificato seguito da un MAC dei messaggi precedentemente scambiati cifrato con la K privata, e il server autenticherà il client se troverà corrispondenza tra quello ottenuto e quello calcolato da lui.

+ E' il metodo più sicuro per fare autenticazione perché si basa su crittografia asimmetrica
+ la superficie di attacco è estremamente ridotta (riguarda soltanto la libreria di TLS)
+ il client non ha bisogno di ricordarsi Username e password.

- non è facilmente applicabile in quanto necessita il possesso di un certificato X.509 da parte del client.
- Il mapping tra certificato e utente a livello applicativo non sempre è implementato dal sistemista.

HTML form-based invece si basa sull'inserimento di username e password direttamente in un form html.

+ Questa metodologia è molto veloce da implementare e flessibile, facile per l'utente (user friendly).

- è anche la procedura più rischiosa e vulnerabile perché la superficie di attacco risulta molto più estesa rispetto alla superficie di attacco di TLS.
- Tecnicamente non importa la sicurezza della pagina in cui si introducono i dati (può anche essere una pagina http) ma è importante che la uri del metodo usato per inviare Username e Password sia sicura (<form .. action = https://...">). Psicologicamente è però necessario implementare https anche nella pagina in cui si mandano i dati perché l'utente non ha conoscenza del contenuto html di una pagina.
- Password memorizzate in un Database

132. Un'azienda vuole fare TLS client auth su un server web: vantaggi e svantaggi e accorgimenti da applicare su client e server.

Vantaggi: autenticazione forte, non richiede all'utente di ricordarsi la password, poca superficie di attacco

Svantaggi: non applicabile perché non tutti hanno un certificato X.509, il sistemista se ha bisogno di auth a livello applicativo deve implementare un mapping semiautomatico e non per forza.

Accorgimenti: HSM sul server per le operazioni di crittografia, Dispositivo sicuro per K privata sul client, HSTS per cui il server indica che l'interazione con UA avviene soltanto tramite HTTPS (prevenendo Protocol Downgrade) e HPKP (Public Key Pinning) che mitiga gli effetti di un attaccante di riuscire a forgiare un certificato falso.

133. Supponiamo di avere un sito web, come si potrebbe fare l'autenticazione dell'utente potendo agire solamente sul nodo di rete che ospita il sito web?

FORM HTML.

134. Considerando il protocollo TLS-1.0, spiegare quali proprietà di sicurezza offre e per ciascuna di esse indicare se è obbligatoria o opzionale e come viene ottenuta.

- Autenticazione del server (obbligatoria). Algoritmo: DSA, k pub con X.509
- Autenticazione del client (opzionale).
- Autenticazione e integrità dei messaggi + protezione da filtering e replay. HMAC = KD (key_auth_client, RecordTls + SequenceNumber), dove seqnumb è implicitamente calcolato. Algoritmi: Sha-2
- Riservatezza dei messaggi. Facoltativa, crittografia 3DES. (client decide la chiave e la comunica al server tramite crittografia a chiave pubblica) DH o DSA

135. Elencare e spiegare le caratteristiche di SSL.

SSL (Secure Socket Layer) è un protocollo di trasporto sicuro, sicurezza di canale, a livello sessione. In particolare permette alle applicazioni di delegare la sicurezza affidandosi a un canale logico quindi rendendo il sistema più sicuro e robusto. Il canale logico SSL è costruito sopra il livello logico TCP. È un protocollo di sicurezza orientato al canale di comunicazione e protegge tutti i dati in transito. Offre autenticazione, riservatezza, integrità + a de messaggi e protezione da filtering e replay. I dati che trasporta sono chiamati record, di formato Type, Version, Length, Fragment. L'architettura di SSL-3 è composta da SSL handshake protocol che si occupa di negoziare chiavi e algoritmi, Change Cipher Spec protocol che è un messaggio che

indica che si sta adottando una nuova soluzione di sicurezza, Alert Protocol invece viene comunicato un allarme a cui seguirà una chiusura di connessione.

136. Approcci TLS-then-proto e proto-then-TLS: spiegare il funzionamento, vantaggi e svantaggi dei due approcci.

I due approcci hanno impatto per quanto riguarda la gestione di Firewall, modifica alle applicazioni e IDS. In particolare:

- **TLS then http**. Prima si apre un canale sicuro, successivamente viene utilizzato il protocollo per il trasporto dei dati. la sicurezza non è garantita dal programmatore del server web ma gestita dal sistemista, che deve attivare TLS prima di rendere accessibile l'applicazione web. Richiede meno lavoro agli sviluppatori, che però non avranno il controllo sui sistemi di sicurezza.
    - **Applicazione**: lo sviluppatore affida la sicurezza a TLS (il sistemista deve garantire di attivare TLS prima di rendere accessibile l'applicazione web)
    - **Firewall**. È facile da gestire perché può far passare il traffico solo nella porta nella versione sicura del protocollo (443 per https)
    - **IDS**. Ho il canale cifrato end to end, quindi i NIDS non possono analizzare il traffico. posso usare al massimo gli HIDS.
- **http then TLS**. I messaggi vengono scambiati sulla porta 80 di http, quella non sicura. Quando si vogliono mandare dati importanti si può attivare la sicurezza col comando STARTTLS.
    - **Applicazione**. Lo sviluppatore deve pensare alla sicurezza applicativa: quando un utente richiede di accedere a risorse protette occorre trasformare il canale in canale sicuro.
    - **Firewall**. Il canale rimane invariato, sempre alla porta 80. Un packet filter non potrebbe filtrare il traffico se volesse far passare canali sicuri, devo implementare un Application Gw che sia in grado di comprendere la richiesta STARTTLS.
    - **IDS**: può vedere il traffico solo finchè non è protetto.

137. Che cosa sono gli step di trasformazione dei dati quando inviati tramite un canale TLS con la cipher suite DHE-RSA-AES-128-SHA?

1. Frammentazione dei dati applicativi
2. Compressione dei dati
3. Calcolo del MAC su dati compressi + padding usando algoritmo SHA definito (KD usando la K generata dal client per Auth)
4. Aggiunta del padding
5. Creazione di IV
6. Cifratura con AES (usando IV + K generata da client per Cifratura)
7. Aggiunta dell'header TLS.

138. Come si può garantire l'autenticazione del traffico HTTP?

http fa una richiesta GET di una pagina web protetta. Risposta dal server: 401, non si chiude il canale ma si manda un popup all'utente chiedendogli di inserire user e pass validi per il reame di autenticazione.

- **http 1.0: Basic Authentication**. User e password vengono concatenati con una stringa, codificati in base64 e spediti in chiaro al server, che farà decodifica e confronto col proprio database. Problema sniffing.
- **http 1.1: Digest autentication**. Si calcola HA1= md5(User || : || realm || : || password), HA2 = md5(Method || Uri) e infine Response = (HA1 ||:|| nonce||: || HA2) per proteggere da replay si usa il nonce, mandato dal server.

139. Spiegare Heartbleed

Heartbleed è un possibile attacco che consiste nel tenere continuamente aperta una connessione senza rinegoziare una sessione SSL. In questo modo un attaccante puo ottenere dati sensibili presenti in un dato blocco di RAM, quali user+pwd e/o chiave privata del server tramite buffer-overflow (se non si usa un HSM, il server tiene la chiave privata in RAM). Si basa sull'estensione Heartbeat che, una volta aperto un canale TLS, continua a scambiare messaggi, anche vuoti, per mantenere la connessione aperta.

140. Indicare quali proprietà di sicurezza sono disponibili tramite il protocollo TLS-1.2. Per ciascuna proprietà indicare se è opzionale o meno, la metodologia usata per implementarla e le eventuali chiavi specifiche o altri parametri di configurazioni necessari.

- **Autenticazione del server (obbligatoria):** CRA asimmetrica mediante sfida implicita. Firma con chiavi RSA. Il server manda il proprio certificato X.509 al client, il client genera una K simmetrica che cifra con la K pubblica del server.
- **Autenticazione del client (facoltativa).** CRA asimmetrica mediante sfida esplicita: il server richiede esplicitamente un certificato al client. Il client gli manda il certificato e i messaggi precedenti cifrati con la Kprivata corrispondente.
- **Riservatezza dei dati (facoltativa)** mediante chiave simmetrica generata dal client
- **Autenticazione + integrità + filtering + replay:** Keyed Digest con algoritmo negoziato all'inizio dell'handshake, MAC = MD(Key_auth_client_to_server || Type || Version || Length || fragment || sequence number). Il SN garantisce protezione da filtering e reply ed è calcolato implicitamente. L akey auth garatnsice autenticazione del messaggio, il digest garantisce integrità.

141. Si vuole controllare l'accesso alle pagine web ospitate da un server operando solo sulla configurazione del server stesso. Identificare le possibili tecniche utilizzabili, indicandone vantaggi e svantaggi.

- **Ingress Firewall.** Si mette un packet filter all'ingresso della rete. Vulnerabile a IPSpoofing, poco sofisticato.
- **IPSec.** Controllo di integrità + autenticazione all'ingresso della rete nel pacchetto IPSec. Svantaggio: va implementato anche il client
- **TLC authN.** Autenticazione del client mediante certificato X.509 che non tutti hanno
- **http basic / digest.** Invio delle credenziali mediante un popup a livello sessione. Invio di pwd in chiaro in base64 (basic) o concatenando user, password, realm, nonce, method e url con stringhe fisse in modo tale da rendere impossibile sniffing o attacco dizionario per trovare corrispondenze.
- **FORM Based AUTHn.** Form in HTML, la forza dipende dalla tecnica utilizzata.

Capitolo 8 - Sicurezza della posta elettronica

142. Quali sono le proprietà di sicurezza di S/MIME clear-signed? Spiegare indicando gli opportuni algoritmi usati e dire se sono obbligatori o opzionali.

S/MIME **clear-signed** implica l'invio di una firma digitale come allegato al messaggio di testo, che viene mandato in chiaro. È utilizzato per consentire la lettura del messaggio anche per chi non possiede Mail User Agent sicuro: in questo caso si indicherà che il messaggio ricevuto è sicuro ma il MUA non è in grado di comprenderne il significato perché non gestisce opzioni di crittografia. Date queste premesse, le proprietà di sicurezza garantite sono:

- Non ripudio: grazie alla firma digitale mediante crittografia asimmetrica
- Security label. I messaggi sono classificati secondo una certa gerarchia di sicurezza (in ambito militare i messaggi sono classificati in unclassified, cioè leggibili da chiunque, e classified, cioè riservati solo a coloro che hanno una certa autorizzazione), secret e top-secret.
- Integrità e autenticazione. La firma viene applicata su un digest del messaggio, perciò vengono garantite entrambe queste proprietà.

Nella versione S/MIME 4.0 gli algoritmi usati sono:

- Firma digitale: curve ellittiche con ECDSA o EDDSA, Digest con Sha-256 + RSA

143. Indicare con una formula la struttura di un messaggio S/MIME per un testo T ed una coppia di chiavi (Kpri, Kpub)

144. Dire che cosa ha in più APOP rispetto a POP e come lo implementa

APOP è una metodologia, una variante di POP per fare autenticazione dell'utente. in particolare, avveniva l'autenticazione mediante sfida simmetrica e sostituisce quello standard di POP in cui username e password venivano spediti in chiaro.

145. Con riferimento ad un sistema di gestione della posta elettronica Internet (MHS, Mail Handling System) identificare i possibili problemi di sicurezza ed indicare quali tecniche di protezione si possono applicare per risolvere o mitigare ciascun problema.

L'invio e la recezione di un messaggio di posta elettronica avviene nel seguente modo:

- L'interfaccia presso cui scriviamo le email si aggancia a un software definito Mail User Agent (in questo caso il web server è il MUA).
- Il MUA comunica con il Mail Submission Agent (MSA) mediante protocollo SMTP (porta 587) che sarebbe il nostro server locale, che ha il compito di accettare o rifiutare le mail in entrata.
- MSA una volta accettate le mail le inoltra al Mail Transfer Agent sempre mediante SMTP (porta 25)
- Il MTA percorre tutta la catena di MTA per farlo arrivare al MTA destinazione
- MTA del destinatario comunica con Message Store, la casella di posta in cui sono situate le mail ricevute.
- Message store custodisce le mail e le inoltra a MUA mediante il protocollo POP o la versione aggiornata IMAP.

Le problematiche relative a un sistema di gestione della posta elettronica sono:

- **Sistema Connectionless** (store-and-forward): il collegamento tra mittente e destinatario non è diretto ma passa attraverso il MTA, che può mantenere i pacchetti memorizzati nei propri hard disk per tutto il tempo che serve per inoltrarli al MTA successivo. Questa parte è al di fuori del mio controllo e non è ritenuta sicura.

- **Sicurezza del MS** su cui vengono memorizzati i messaggi di posta elettronica
- **Compatibilità con le infrastrutture** già esistenti (in particolare con l'infrastruttura RFC 822)

146. S/MIME: indicare gli algoritmi di cifratura, hashing e firma, sia obbligatori che opzionali, ed indicare come ciascuno di essi viene utilizzato all'interno di S/MIME.

• Digest: SHA-1 (obbligatorio) o MD5.

• Firma digitale: DSS (obbligatorio) o digest+RSA (soluzione più usata).

• Scambio chiavi: Diffie Hellman (obbligatorio). In realtà la pratica comune è quella di calcolare una chiave di messaggio cifrandola con la chiave RSA del destinatario.

• Cifratura del messaggio: 3DES o RC2/40 (entrambi obbligatori).

147. Dove è meglio fare l'autenticazione del mittente in un sistema di posta tra MTA e MSA?

Il MSA (mail submission agent) è l'entità che si occupa di autenticare gli utenti. Questa avviene con SMTP-Auth. In seguito al comando EHLO (da ESMTP) viene inviata una lista di opzioni supportate per fare autenticazione. è possibile fare autenticazione in 4 modi:

- AUTH Login. Spedizione di Username e password in due passaggi, codificate in base 64 (vulnerabile allo sniffing)
- AUTH Plain. Spedizione di username concatenato alla password, riduce RTT ma sempre vulnerabile a sniffing
- AUTH CRAM MD5. Autenticazione mediante sfida simmetrica (Hmac di nonce + password in risposta). Problema: database delle password deve essere in chiaro.
- TLS. Viene invocato il comando STARTTLS in cui viene creato un canale sicuro dentro cui inviare le password.

148. S/MIME: breve descrizione.

MIME è uno standard successore di RFC 822, poteva supportare diverse codifiche di caratteri, invio di allegati e formato ricorsivo delle mail. La sua versione sicura prende il nome di S/MIME, che supportail formato PKCS#7 e CMS. Per la crittografia asimmetrica il formato dei certificati è X.509. e può offrire:

- **Firma digitale**. Può essere inviata come allegato (canonizzazione testo + allegati, digest, cifro con Kpri per firmare). mandato in una struttura dati S**/MIME.p7s**
- **Cifrare messaggi**. Il testo cifrato è inserito come allegato: una mail cifrata non avrà contenuto ma avrà un allegato, in una struttura dati **S/MIME.p7n**. L'approccio più utilizzato è quello enveloped data: cifro con Kpub la Ksimm con cui si decifrerà il messaggio.
- **Cifrare e firmare messaggi**. L'email prima viene firmata (canonicizzazione + digest + cifratura con Kpri) e poi viene ulteriormente cifrata assieme a tutti i suoi allegati (firma compresa) con Ksimmetrica. Anche qui approccio enveloped data. Struttura dati: S/MIME.p7n contenente al proprio interno S/MIME.p7s.

149. Con riferimento all'anti-spam per le MTA in ingresso, descrivere nolisting, greylisting, basato su DNS, i loro vantaggi e svantaggi.

Il mail spamming attualmente corrisponde al 55% del traffico mail. È fastidioso perché richiede un sovradimensionamento dei server per mail spazzatura, che spesso però causano attacchi malware e phishing. I server normalmente hanno un'entità che si occupa di autenticare il client che vuole mandare posta (MSA), tuttavia è possibile per alcuni spammers utilizzare servizi di Open Mail che non utilizzano MSA per poter inviare lo spam. Per cercare di filtrare lo spam in entrata di seguito verranno mostrate delle soluzioni possibili:

- **Nolisting**. Si basa sulla teoria che gli spammers non vogliono perdere tempo: non attende ritrasmissioni. Se mandare mail diventa un processo lungo e complicato per un dato dominio, lasciano perdere e provano per un altro dominio. Vengono messe più copie di server, non tutti inviano la nostra posta: se MX primario non risponde, si contatta MX secondario. Un attaccante che vuole mandare quanta più email possibile e contatta il primario, vedendo che non risponde, lascerà perdere. Un utente legittimo invece proverà a contattare il MX secondario. Anche questa soluzione però fa perdere tempo a utenti legittimi. Tuttavia il vantaggio è che l'MTA non viene sovraccaricato perché si riceve solo posta valida.
- **Greylisting**. Si basa sul principio precedente, ossia che gli spammers non vogliono perdere tempo. Se arrivano email da un mittente non ancora conosciuto, verrà inviato un errore temporaneo che inviterà l'utente a ritentare l'invio dopo tot tempo. Se l'email è legittima l'utente ritenterà l'invio, e questa volta l'operazione viene accettata. Al contrario se venisse da uno spammer, lascerebbe perdere. Purtroppo questa tecnica ritarda tutti i messaggi di posta elettronica ricevuta.
- **DNS BlackList o WhiteList**. Quando si riceve una richiesta di collegamento da parte di un MTA esterno, si guarda il suo dominio e si verifica se il dominio di provenienza appartiene a un noto dominio di spam grazie a un lookup DNS. Lo svantaggio è che se il mio dominio è stato attaccato e rientra nella lista di spam noti, è difficile uscirne.

150. Comando AUTH di ESMTP

Il comando AUTH di ESMTP avviene successivamente al comando EHLO di presentazione, e mostra tutte le possibili opzioni di autenticazione offerte dal protocollo. In particolare offre:

- Login: U + P separatamente in base64 (sniffing)
- Plain (U || P) analoga al precedente, risparmio RTT
- CRA-MD5 (MD5(Nonce || Pwd)) sfida simmetrica, problema DB in chiaro
- TLS: creazione canale sicuro su cui inviare le credenziali.

151. Autenticare il mittente di posta elettronica: MS, MSA o MTA?

MSA

152. Con riferimento ai formati per la creazione di un documento elettronico con firma digitale, descrivere le soluzioni disponibili e discuterne i relativi vantaggi e svantaggi.

- Enveloping signature (PKCS #7)

vantaggi: applicabile su tutti gli oggetti

svantaggi: bisogna modificare le applicazioni

- Enveloped signature (PDF)

vantaggi: wrapping/wrapper

svantaggi: utilizzabile solo per quell'applicazione

- Detached signature (PKCS #7)

vantaggi: applicabile su tutti gli oggetti

svantaggi: link tra firma e documento

XML / JSON: metodi di rappresentare dati in maniera più distribuibile possibile (oggi) -> Spreco di spazio. Descrizione della struttura dati.

Mondo del binario: ASN.1 (30 anni fa) descrive come è fatta la struttura dati. (meno spazio).

- **BER**. Per accedere ai dati codificati in questo formato sono state inventate le Basic Engoding Rules per trasformare i dati in binario, gli stessi dati possono essere rappresentati in modi diversi, alterando gli hash.
- **DER**: rappresentazione univoca per ogni tipo di dato. (1 tipo di dato – 1 rappresentazione). È sempre una codifica binaria.
- **PEM,** codifica in base64 dei dati codificati in DER.

Formati di firma

- **Enveloping signature** (*sign*). Il documento è in una struttura dati firmata: dati firmati, documento e firma digitale in un'unica struttura dati.

  + applicabile a tutti gli oggetti
  - Richiede la modifica delle applicazioni



- **Enveloped signature**. Applico una firma a un PDF. La firma è un campo all'interno del documento stesso.

  + Fa da wrapper
  - Utilizzabile solo da quell'applicazione

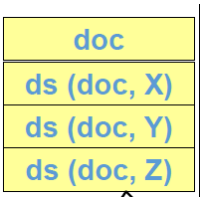


- **Detached signature**. Firma separata, di tipo *clear signed*. Si calcola la firma su documento e si convoglia sia la firma sia il documento in 2 file.

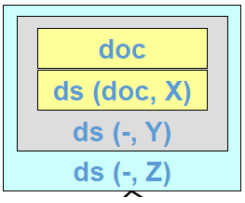
  + Applicabile a tutti gli oggetti
  - Necessita di un link tra firma e documento



Firme multiple parallele o indipendenti. Ogni firma del documento originale è indipendente. Si calcola in parallelo ed è comoda.



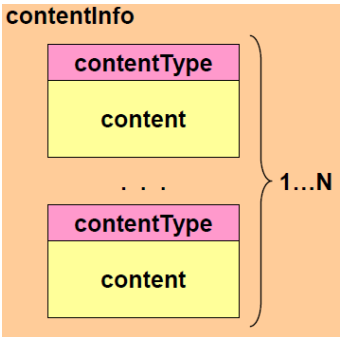
Firme multiple gerarchiche o sequenziali. Doc + firma diventa il contenuto da firmare per l'altra firma. Prestazioni simili ai precedenti.



Formato PKCS#7 / CMS. Ho una struttura dati esterna, contentinfo, all'interno di cui c'è una sequenza di contenuti caratterizzati da tipo e contenuto. Assomiglia a XML: <ContentInfo> <Contenttype = > </></>.

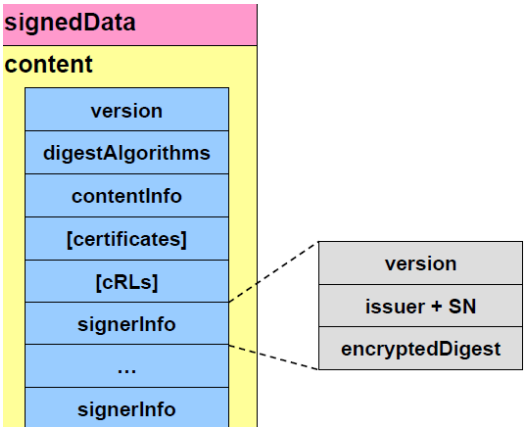
ContentType possono essere:

- ***Data***, senza sicurezza (codifica di una generica sequenza di byte)
- ***SignedData***, dati + N firme parallele
- ***envelopedData***, dati cifrati con crittografia simmetrica + chiavi di messaggio cifrate con crittografia asimmetrica (RSA)



- ***SignedAndEnvelopedData***, prima firmo e i dati firmati vengono cifrati e incapsulati secondo envelopedData
- ***digestData***: dati + digest, non garantiscono la sicurezza
- ***encryptedData***: dati cifrati con algoritmi simmetrici

SignedData. Il contenuto è una struttura con una sequenza di campi



- **versione** (pkcs7 o CMS)
- gli **algoritmi** di digest usati per calcolare le firme digitali. Vengono scritti subito così si iniziano a caricare i moduli per processarli.
- **Contentinfo**, che da informazioni sul contenuto vero e proprio.
- **Contenuti opzionali**: posso inserire al loro interno le strutture dati rilevanti. In questo modo non devo perdere tempo a procurare il certificato.
- **firme parallele**, ognuna delle quali ha *versione*, *identificativo* univoco del firmatario (certificato grazie a SN + certification autority) e la *firma digitale* propriamente detta.

#Esempio: CMS Signed Data in ASN.1. ricorda le Struct in C.
Identifiers: ogni algoritmo noto ha un Object ID

```
SignedData ::= SEQUENCE {
        version CMSVersion,
        digestAlgorithms DigestAlgorithmIdentifiers,
        encapContentInfo EncapsulatedContentInfo,
        certificates [0] IMPLICIT CertificateSet OPTIONAL,
        crls [1] IMPLICIT RevocationInfoChoices OPTIONAL,
        signerInfos SignerInfos }

SignerInfo ::= SEQUENCE {
        version CMSVersion,
        sid SignerIdentifier,
        digestAlgorithm DigestAlgorithmIdentifier,
        signedAttrs [0] IMPLICIT SignedAttributes OPTIONAL,
        signatureAlgorithm SignatureAlgorithmIdentifier,
        signature SignatureValue,
        unsignedAttrs [1] IMPLICIT UnsignedAttributes
           OPTIONAL }
```

Corporate

5) Definire i tre principali approcci alla stima dei rischi (es. risk assessment) (3-4 punti).

I 3 principali approcci alla stima dei rischi (risk assessment) sono:

- **Approccio quantitativo**. Vengono associati grandezze a numeri mediante formule matematiche. I valori sono paragonabili in base agli ordini di grandezza stabiliti
- **Approccio qualitativo**. Vengono definite delle fasce di rischio, in genere basse – medio/basse – medie – medio/alte – alte.
- **Approccio semiquantitativo**. Associa le grandezze qualitative a grandezze quantitative, definendo una scala di valori. Ad esempio: 0-3 (basso) 4-6 (medio) 7-9 (alto): quindi viene prima identificato un numero proveniente da una serie di formue, e queste vengono rimappate in un valore qualitativo. Questo approccio è utilizzato da OWASP, in cui si definiscono dei valori numerici per ogni fattore definito
    - P(Threat agent factors (un valore per ogni sottocategorie) + Vulnerability Factors)
    - P(technical impact + business impact)
    - Si mappano i valori in output da queste probabilità su una tabella (X = P(1), Y = P(2)) e si verifica il rischio globalmente.

6) Definire cosa sono le CVE e le CWE e da chi sono state definite e chi le gestisce. Infine, spiegarne i principali aspetti comuni e le differenze (5-6 punti).

CVE (common vulnerability and exposure). È una metodologia standard che descrive i problemi di vulnerabilità o esposizione noti trovati nei software. Sono identificati da un numero univoco e mantenuti nel National Vulnerability Database, organizzati secondo il nominativo CVE_anno_numerodiserie_descrizione. Il database è manetnuto nel MITRE corporation.

Il **CWE** invece (Common Weakness Enumeration) è raccolta di errori di programmazione presenti nei software di produzione, definiti poor coding parctises. Questi vengono numerati e inseriti in una CWE, ossia una lista contenente tutti questi errori. In genere, sono monitorate da developer, tester e chi usa il software ed è interessato alla sua correttezza.

Differenze e aspetti comuni. Una CWE, potrebbe causare una CVE. Non è garantito che succeda, ma può dare la possibilità che la CWE non venga sfruttata direttamente ma vengano sfruttati i suoi "effetti collaterali" che questa potrebbe causare. Per questo motivo, il fatto stesso che esista un CWE nel software è un primo campanello di allarme. Da questo punto di vista, si può assumere che una vulnerabilità può essere causata da una o più CWE (l'hacker sfrutta un errore del software per ottenere l'accesso a un sistema), una CWE non genera per forza una CVE.

Le figure professionali aziendali che utilizzano CVE e CWE sono:

- **Software Flaw Manager**, dipartimento sviluppatori. Crea le patch per mitigare le vulnerabilità dopo una CVE e una CWE
- **Patch Manager**, le aziende che usano un software, che ricerca un'istanza di vulnerabilità note CVE su tutte le macchine e risorse aziendali, e ricerca le patch appropriate al fine di testarle e applicarle ai dispositivi in produzione.

7) Un'azienda ha effettuato un Vulnerability Assessment e identificato molti sistemi (es. server, PC utenti, dispositivi di sicurezza, sistemi legacy) che presentano vulnerabilità che richiedono di essere corrette. Seguendo le direttive del NIST, proponete una strategia per scegliere un ordine di applicazione delle patch che minimizzi l'esposizione ai rischi di sicurezza e riduca i disservizi (5-6 punti).

- **Subsets**. Le patch vengono prima applicate ai piccoli gruppi rappresentativi delle varie categorie (ad esempio patch per windows, per linux etc)
- **Standard first**. Vengono trattati il prima possibile tutti i dispositivi che non daranno problemi
- **Difficult ones later**: successivamente vengono trattati i sistemi non standard (multiplatform, desktop system, legacy) che potrebbero necessitare di interventi manuali
- **Cover all**. infine vengono coperti tutti i sistemi non coperti precedentemente. (unmanaged host, offline host, firmware). Per questi dispositivi è consigliato l'uso di un sistema di Enterpreise Patch Management Tool, che automatizzano il sistema

8) Spiegare cosa è un SIEM e quale importante funzionalità di sicurezza aiuta a svolgere. Indicare infine un esempio di azienda che potrebbe aver bisogno di un SIEM (3-5 punti).

Un SIEM (Security Information and Event Management) è una famiglia di tool che si occupa di risolvere i problemi correlati alla sicurezza, e si presta molto bene all'acquisto (sia come dispositivo hardware sia come dispositivo cloud) da parte delle aziende. I tool presenti al suo interno si occupano di:

- **SEM** (event management): si occupa di continuous monitoring in tempo reale, analizza log ed eventi e monitora e correla gli eventi e la risposta agli incidenti
- **SIM** (information management) produce documenti e report strutturati in documenti organizzati in seguito all'analisi di dati di log.

SIEM reagisce ai pericoli di informatica presenti e futuri grazie al supporto dell'AI. È consigliato soprattutto per le aziende che lavorano su dati sensibili di utenti.